Gimel Foundation

Gimel Foundation gGmbH i.G.
GiFo-Request for Comments: 0170
Obsoletes: -
Category: Standards Track
Version: 0.9.1 (Working Draft – Under Vendor Review)

G. Wehberg, S. Raghuthaman and the Architecture Working Group of Gimel Foundation
6. May 2026

G-Commerce Integration Profile – Combined Credential and Platform bound Enforcement (CCPE-F)

Abstract

CCPE-F (G-Commerce) is the commerce-authorization profile of the GAuth framework. It lets an autonomous agent transact with a vendor on a principal's behalf under a signed delegation credential, while the vendor's own platform-side checks still apply.

The profile defines:

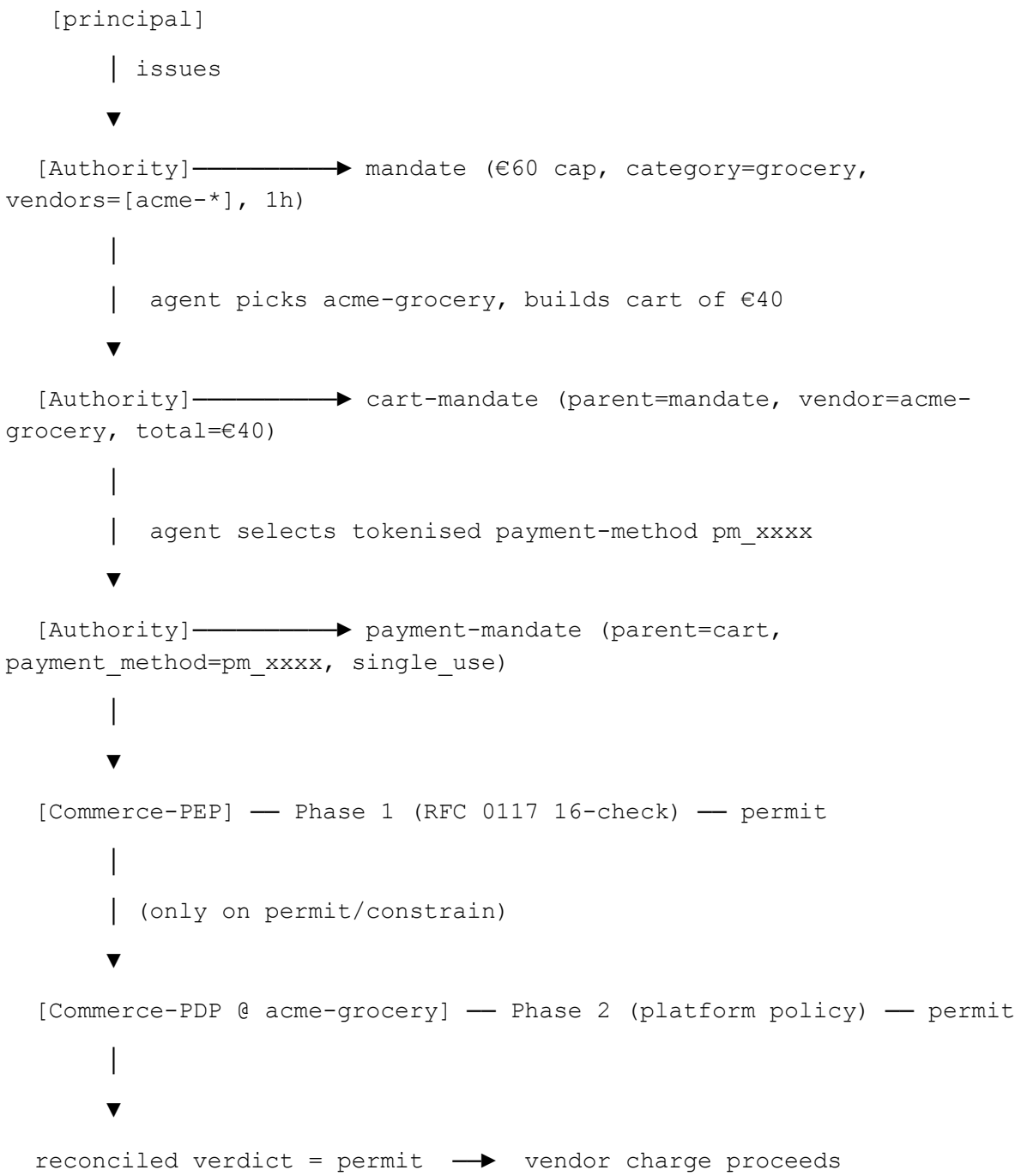
- a Commerce-Mandate envelope (a Power-of-Attorney credential per RFC 0115, specialised for commerce);
- a three-phase decision surface - mandate → cart → payment — with order-preservation as an integrity invariant;
- a bipolar enforcement chain — Power-PEP (credential-bound, Phase 1) followed by Commerce-PDP (platform-bound, Phase 2), reconciled by more-restrictive-wins;
- a per-Phase-2-call metering hook with three open-core symmetry invariants;
- a single normative integration scenario over the Universal Commerce Protocol (UCP) substrate via a Foundation-owned vendor-extension capability, with informative cookbooks for Stripe, Shopify, Amazon Pay, Open Banking / PSD2, and the W3C Payment Request API.
- a deployment-scenario taxonomy — S1 (pure platform-native, no Foundation artefact), S2 (two-artefact via the §4 UCP vendor-extension capability, Recommended and the conformant scenario), S3 (all-in-one merged-credential where the vendor extends its native payment artefact with PoA-shape attributes inline) - with the in-scope-of-RFC ≠ conformant-to-G-Commerce distinction made explicit;
- a seven-disadvantage structural critique of the S3 single-artefact shortcut (cap-and-scope drift, missing principal-delegation event, three-phase chain absence, lifecycle entanglement, cross-vendor interoperability break, governance-model-vs-credential-format category error, and the Phase-2 artefact-discipline cannot-supply-Phase-1 result) closing with an explicit non-conformance statement;

- a scenario-keyed conformance mapping (§4.5a) requiring every G-Commerce Conformance Statement to name its deployment scenario, with the audit-trail field `ccpe_f_scenario` reserved on the wire.

Status of unresolved items, presentation gaps (JSON-Schema/CDDL formalisation, additional vendor cookbooks, Strict / Behörde profile bodies, PQC migration, regulator-bound audit-export format) is enumerated at §13.

How CCPE-F Works in 60 Seconds (Informative)

A worked example - a personal-shopper agent buys a €40 grocery order on behalf of its principal at vendor acme-grocery:



```
audit:    commerce.action_decided + commerce.platform_bound.decided

metering: commerce.decision.metered  (one record per Phase-2 call)
```

Three things that make this profile distinct from a "just present a JWT" flow:

- Three sequential mandates (mandate / cart / payment), each parent-bound, so the principal's delegation can't be silently widened mid-flow.
- Two-stage enforcement — the Power-PEP enforces what the principal delegated; the Commerce-PDP enforces what the vendor's platform allows. The stricter of the two wins. A Phase-1 deny short-circuits Phase 2.
- Cascade revocation — revoking any mandate at the Authority cancels in-flight platform-side artifacts (PaymentIntents, ChargePermissions, carts) and emits commerce.cascade.revoked.

If the Commerce-PDP doesn't answer within phase2_timeout_ms, the mandate's fail_disposition decides: fail_closed denies; fail_drop_payment_only denies payment-class actions but lets non-payment actions through if Phase 1 already permitted.

Status of This Memo

This is a Gimel Foundation Standards Track document.

This document is a product of the Gimel Foundation (GiFo). It represents the current consensus of the Gimel Foundation community. It has performed review and has been approved for publication.

Information about the status of this document, any errata, and how to provide feedback on it may be obtained at https://gimelfoundation.com or https://github.com/Gimel-Foundation.

Legal Notice

Copyright © 2026 Gimel Foundation and the persons identified as the document authors. This document is licensed under Apache License 2.0 per GiFo-RFC 0090; see the GiFo Legal Provisions for the full grant and any reservations.

This document is subject to the Gimel Foundation's Legal Provisions Relating to GiFo Documents (see http://GimelFoundation.com or https://github.com/Gimel-Foundation) in effect on the date of publication of this document. Please review these documents carefully, as they describe your rights and restrictions with respect to this document. Code Components extracted from this document must include License text as described in Section 4. of the GiFo Legal Provisions Relating to Gimel Foundation

Documents and are provided without warranty as described in the Provisions and its respective license conditions.

The distinguished GAuth standard is protected by copyright. Patent for GAuth is pending (PCT). GAuth licensing is not covering the following Exclusions, which are subject to separate license conditions and are also protected by copy right as well as pending patent:

- AI-enabled Governance,
- Web3-Integration,
- DNA-based Identity and PQC associated.

These domains are excluded from the open-source GAuth specification and are governed by separate Gimel Technologies commercial licenses.

GAuth is an open-source standard and can be based on OAuth, OpenID Connect and MCP. Copyrights and licenses of the GAuth building blocks apply accordingly.

GAuth is a registered trademark of the Gimel Foundation gGmbH i.G. CCPE, CCPE-A, CCPE-B, CCPE-C, CCPE-D, CCPE-E, CCPE-F, CCPE-G, G-Commerce, G-AGT, G-PaC, G-Com, G-Code, G-IoT, and G-IBE are trademarks of the Gimel Foundation. All other marks are the property of their respective owners. UCP is a trademark of the UCP Foundation; Stripe is a trademark of Stripe, Inc.; Shopify is a trademark of Shopify Inc.; Amazon Pay is a trademark of Amazon.com, Inc.; PSD2 and Open Banking are descriptive references to EU regulatory frameworks; Payment Request API is a W3C Recommendation.

This document is published under Apache License 2.0 per GiFo-RFC 0090 and the other Legal Terms of Gimel Foundation.

Notational Conventions

The key words Must, Must Not, Required, Shall, Shall Not, Should, Should Not, Recommended, Not Recommended, May, and Optional in this document are to be interpreted as described in BCP 14 (RFC 2119, RFC 8174) when, and only when, they appear in bold capitalised form.

The term CCPE-F designates the F-profile of the CCPE family per the title of this document.

The term mandate denotes a Commerce-Mandate per §3.1 unless qualified otherwise. Commerce-PEP denotes the Commerce-Profile Policy Enforcement Point per §3.3. Commerce-PDP denotes the platform-bound Phase 2 evaluator per §2.5.b. Power-PEP denotes the credential-bound Phase 1 evaluator per RFC 0117. Authority denotes the mandate-issuance and lifecycle service per §2.4.b.

References to UCP capabilities use the UCP Foundation's published namespace conventions: dev.ucp.<capability_family>.<capability_name> for UCP-Foundation-sanctioned capabilities and com.<vendor>.<capability_family>.<capability_name> for vendor-extension capabilities. CCPE-F operates exclusively over a vendor-extension capability under the Foundation-owned namespace com.gimel.gauth.commerce_mandate; see §4.

Content

1. Scope

2. Domain Architecture

3. Normative Concepts

4. Single Normative Integration Scenario — G-Commerce via UCP-Mediated Mandate Carriage

5. Concept Mapping — GAuth/CCPE ↔ UCP (Informative)

6. Cryptographic Requirements

7. Security Considerations

8. References

9. Conformance Levels and Reservations

10. Acknowledgments

11. How to Suggest a Correction

12. Open Issues

Appendixes

Appendix A — Vendor Cookbook: Stripe (Informative, Preliminary)

Appendix B — Vendor Cookbook: Shopify (Informative, Preliminary)

Appendix C — Vendor Cookbook: Amazon Pay (Informative, Preliminary)

Appendix D — Vendor Cookbook: Open Banking / PSD2 (Informative, Preliminary)

Appendix E — Vendor Cookbook: W3C Payment Request API (Informative, Preliminary)

* * *

1. Scope

1.1 What This RFC Does

a. Defines CCPE-F (G-Commerce), the integration profile of the GAuth Authorization Framework (RFC 0111) for the agent-to-vendor commerce-authorization domain.

b. Specifies the Commerce-Mandate envelope (§3.1) - a Power-of-Attorney credential per RFC 0115 specialised for the mandate / cart / payment phase classes, with phase-class binding, parent-mandate chain, parent-chain freshness bounds, and forward-compatibility envelope.

c. Specifies the Commerce Power-of-Attorney (Commerce-PoA) lifecycle aggregation (§3.2) and the cascade-revocation invariants.

d. Specifies the Commerce-PEP and the Decision Envelope (§3.3) under the unified three-value verdict vocabulary {permit, deny, constrain} plus a separate obligations array.

e. Specifies the Commerce Audit Trail (§3.4) and the persistence-before-stream invariant.

f. Specifies the Commerce Decision Metering hook (§3.5) and the three open-core symmetry invariants.

g. Specifies the single normative integration scenario over UCP (§4) and the conformance checklist (§4.5).

h. Specifies the non-conformant variant taxonomy CCPE-F-NCI / NCP / NCO (§4.6).

i. Specifies the cryptographic baseline (§6), including the §6.2 canonicalisation and §6.3 transport anchors.

j. Specifies the security considerations (§7), including the substrate-governance threat (§7.10).

k. Reserves the §9.1 Reservations Catalogue.

l. Provides informative vendor cookbooks based on publicly available vendor documentation (Appendices A–E).

m. Substrate-governance caveat. The §4 single normative integration scenario is operated over the Universal Commerce Protocol (UCP), a substrate governed by the UCP Foundation, of which the Gimel Foundation is not a Tech-Council member as of the v0.9.1 publication date. Deployments Should track UCP capability-namespace and discovery-document conventions actively; an upstream non-backwards-compatible change to UCP would break the §4 conformance path until §1.3a / §4 are updated.

n. Specifies the deployment-scenario taxonomy S1 / S2 / S3 (§2.6) and the structural disadvantages of the single-artefact merged-mandate shortcut (§2.7), with scenario-keyed conformance mapping at §4.5a.

1.2 What This RFC Does Not Do

This RFC does not:

a. Modify, supersede, or characterize any third-party agent-payment, agent-commerce, or commerce-protocol specification beyond the scope and register of the citations explicitly stated at §5 and §8.

b. Make any recognition of legal effectiveness, originality, novelty, prior-art status, patentability, or completeness of any third-party specification cited.

c. Specify any deployment-time or runtime obligation that an implementation of a third-party commerce specification adopt CCPE-F.

d. Specify any settlement-side, payment-network-side, or fraud-detection-side semantics; out of scope per §1.4.d–h.

e. Specify any commerce-side artifact at the user-interface or vendor-storefront register; CCPE-F operates at the authorization-decision register only.

f. Specify any commercial billing semantics. The §3.5 metering hook is a Foundation-specified protocol contract; the billing fact downstream is governed by Gimel Technologies commercial agreements with deployment operators and is out of scope. See §3.5 Two-Hats Footnote.

g. Specify any tariff-tier definitions. The §3.5.1 tariff_tier enum values O/S/M/L are placeholders whose semantics are defined in the Gimel Technologies open-core commercial schedule (informative reference at §8.2) and are out of scope of this RFC.

h. Constitute any election against, waiver of, or pre-condition to any specific intellectual-property remedy.

i. Evaluate vendors, recommend solutions, compare providers.

1.3 Relationship to Adjacent Specifications

The CCPE-F architectural surface depends only on the GAuth credential-layer baseline, including:

- GiFo-RFC 0110: GAuth Protocol Engine. Authority, Power-PAP.
- GiFo-RFC 0111: GAuth Authorization Framework. CCPE-F is an integration profile of RFC 0111.

- GiFo-RFC 0115: Power-of-Attorney Credential Definition. Commerce-Mandate is a specialisation of the RFC 0115 envelope; signature-algorithm baseline anchored to RFC 0115.
- GiFo-RFC 0116: GAuth Interoperability — Extended Token / W3C VC Representation. Optional VC-form mandate carriage.
- GiFo-RFC 0117: GAuth PEP Interface. Power-PEP at Phase 1 implements the RFC 0117 16-check pipeline; verdict vocabulary aligned with RFC 0117.
- GiFo-RFC 0118: GAuth Management API. Authority issuance / revocation / introspection surface.
- GiFo-RFC 0160: G-Audit Profile. Audit-event payload baseline for the §3.4 stream.
- GiFo-RFC 0180 v0.3 G-Code AI-Coding-Assistant Governance Profile.
- GiFo-RFC 0210 (CCPE-G) Identity-Bound Enforcement Profile. Cited informatively, as the source of the §5.1 synthetic-Commerce-Mandate bridge inbound.
- Universal Commerce Protocol (UCP Foundation). Substrate for the §4 normative integration scenario via the Foundation-owned vendor-extension capability com.gimel.gauth.commerce_mandate. §4, §5

The architectural-pattern lineage of CCPE-F (three-service Console / Authority / Commerce-Runtime pattern; bipolar credential-bound + platform-bound enforcement; mandate envelope shape; non-conformant-variant taxonomy convention) is shared across the CCPE family. The lineage is acknowledged at §10.

1.4 Normative Technology Exclusions

The following CCPE-F-specific adjacencies are out-of-scope:

a. Consumer payment-fraud detection internals — out of scope.

b. PCI-DSS cardholder-data-environment internals — out of scope. CCPE-F mandates carry tokenised payment references, not PAN material; the §6.6 prohibition on PAN carriage is normative.

c. Native cryptocurrency and CBDC settlement substrates — no settlement-side semantics.

d. In-store / POS hardware payment terminal internals — out of scope.

e. BNPL credit underwriting and money-transmission compliance — out of scope.

1.5 No-Waiver Disclaimer

The technical descriptions and concept-mappings contained in this document serve solely the purpose of architectural comparability between specifications. They do not constitute recognition of the legal effectiveness, originality, or completeness of the referenced third-party specifications. Existing rights, claims, and defences — including, but not limited to, patent rights and the licence terms set forth in GiFo-RFC 0090 — remain unaffected by this document.

In particular, and without limiting the generality of the foregoing:

a. No estoppel by silence. The descriptive citation does not constitute the Gimel Foundation's, any contributor's, or any member's acquiescence in, consent to, validation of, or waiver of any objection to that third-party material.

b. No grant by description. No licence is granted by this document to any patent right, copyright (beyond the Apache 2.0 grant covering this document's own text), trade-secret right, or other intellectual-property right.

c. No characterization beyond the stated comparison.

d. No election against remedies. The Gimel Foundation reserves all rights and remedies in respect of its intellectual-property portfolio.

e. No commercial-arrangement encoding. The §3.5 metering-hook protocol contract is a Foundation-specified normative requirement on any operator emitting commerce.decision.metered events; it Does Not encode any commercial billing arrangement. Commercial billing arrangements between deployment operators and Gimel Technologies (or any other commercial counterparty) are governed by separate commercial agreements and are out of scope of this RFC.

This §1.5 is the normative anchor for the No-Waiver framing.

2. Domain Architecture

2.1 The Commerce-Authorization Domain

The commerce-authorization domain comprises three sequential phase classes:

a) Mandate phase. The agent expresses a commercial mandate on behalf of the principal — for example, "purchase a category-X item under price-cap Y from any of the vendors V1, V2, V3 within the next hour".
b) Cart phase. The agent has selected a specific vendor and a specific cart composition consistent with the mandate.
c) Payment phase. The agent presents a payment instrument selection (payment method, payment-account reference, optional payment-network rails) for the cart.

The three phases are sequential and order-preserving: a payment-phase decision Must Not be evaluated before its corresponding cart-phase decision; a cart-phase decision Must Not be evaluated before its corresponding mandate-phase decision.

2.2 Bipolarity: Platform-Bound Flow and Credential-Bound Flow

a) Platform-Bound Flow. The decision is evaluated by a vendor-side or marketplace-side platform service. Authoritative source: platform operator. Bound artifact: platform-side configuration.
b) Credential-Bound Flow. The decision is evaluated by a credential layer that verifies a signed delegation credential issued by the principal. Authoritative source: principal. Bound artifact: Power-of-Attorney credential per RFC 0115.

A conformant CCPE-F deployment Must operate both flows in chain: the credential-bound flow produces the Phase 1 verdict (Power-PEP); the platform-bound flow produces the Phase 2 verdict (Commerce-PDP). The two verdicts are reconciled per §2.5 such that the more restrictive of the two is the final decision.

The bipolarity is the central architectural feature of CCPE-F.

2.3 Architectural Deltas

a) Counterparty asymmetry. The platform-bound flow is operated by a party the deployment Does Not control.
b) Three-phase decision surface. Unique to the commerce domain.
c) Tokenised-payment substrate. The mandate envelope carries the tokenised reference, not the underlying material; §6.6 PAN-carriage prohibition applies.
d) Adopter-side substrate ecosystem. A published commerce-protocol substrate (UCP) is operated by a third-party governing body.

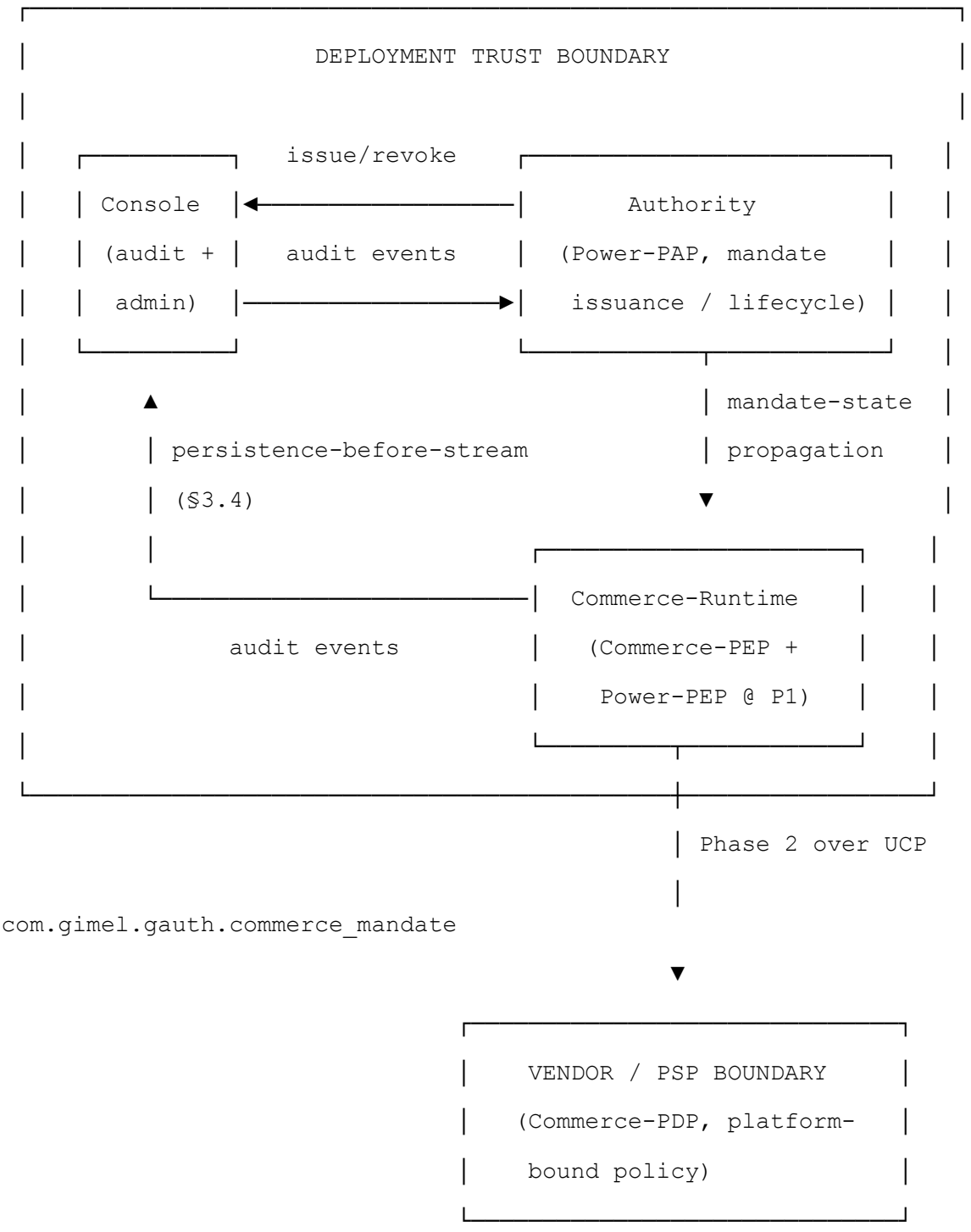
2.4 Three-Service Pattern

A conformant CCPE-F deployment comprises three logically-distinct services. Conflation of any two roles into a single service is non-conformant.

a) Console. Operator-facing surface. Hosts the audit-trail event store, mandate registry, governance-profile administration surface, and operator-facing dashboards.
b) Authority. Mandate-issuance and lifecycle service. Hosts the Power-PAP (per RFC 0110 §4), issuance pipeline, mandate-revocation pipeline, and mandate-state propagation pipeline.

c) Commerce-Runtime. Transaction-time enforcement service hosting the Commerce-PEP.

Trust-boundary diagram (informative):



Conflations to avoid: Console ⇄ Authority (operator can read-write its own audit trail); Authority ⇄ Commerce-Runtime (issuer can self-validate without independent

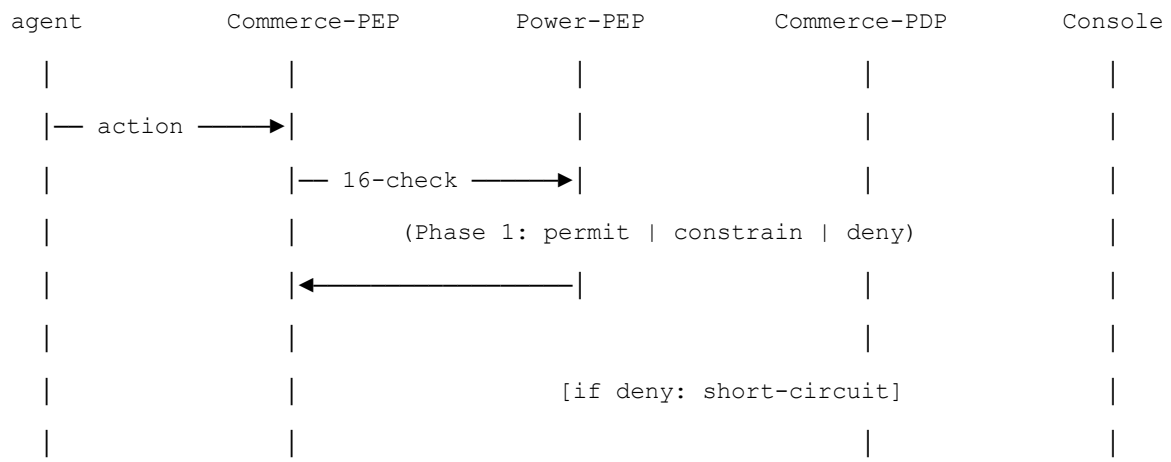
enforcement); Console ⇄ Commerce-Runtime (audit consumer can rewrite its own decisions).

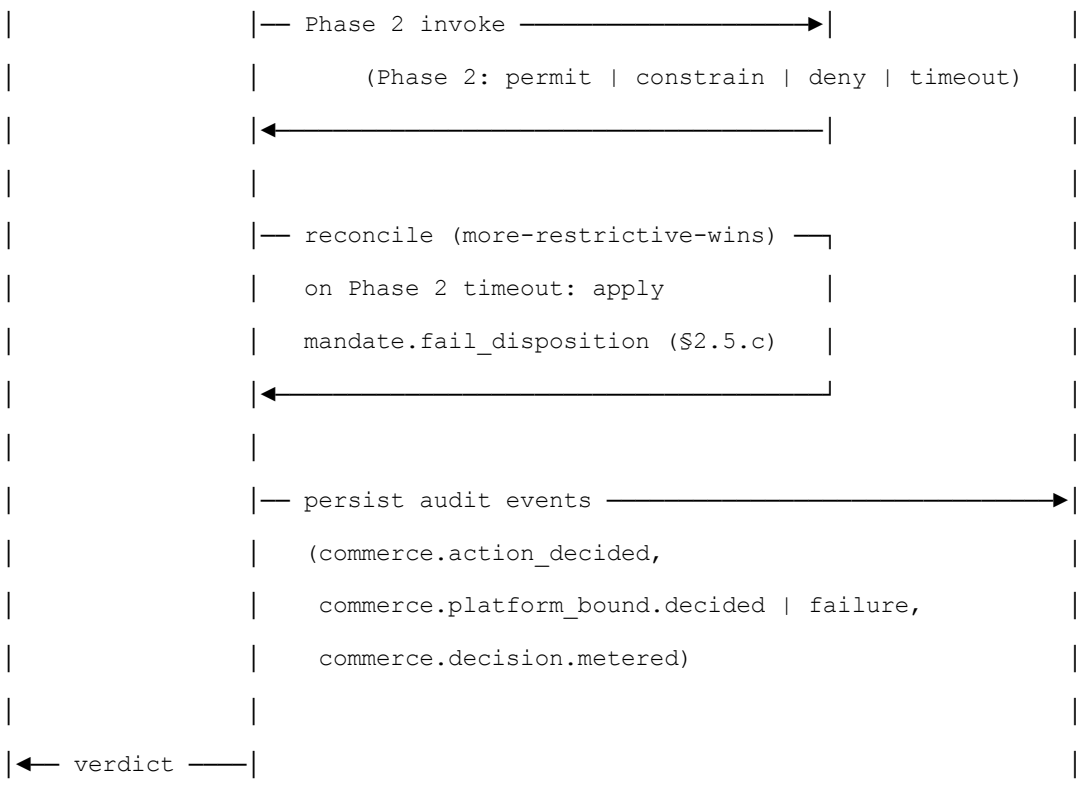
2.5 The Power-PEP → Commerce-PDP Chain

a) Phase 1 — Credential-bound enforcement. Power-PEP runs the 16-check pipeline of RFC 0117 against the active Commerce-Mandate. Verdict ∈ {permit, deny, constrain} with optional obligations array. A Phase-1 deny short-circuits.
b) Phase 2 — Platform-bound enforcement. Commerce-PDP returns Phase 2 verdict ∈ {permit, deny, constrain} with optional obligations array.
c) Reconciliation. More-restrictive-wins: deny > constrain > permit. Where both phases return constrain, obligations are merged by union. Where a phase returns permit with obligations and the other returns permit without obligations, the reconciled verdict is permit with the union of obligations. Where Phase 2 returns no verdict within the deployment-declared phase2_timeout_ms (§3.1.5), the reconciled verdict is derived from the mandate's fail_disposition: fail_closed reconciles to deny; fail_drop_payment_only reconciles to deny for payment-class actions and to permit for non-payment-class actions where Phase 1 verdict was permit. The Commerce-PEP Must emit commerce.platform_bound.failure with the diagnostic obligation phase2_unreachable populated in the obligations field of the persisted reconciliation record.
d) Phase-order preservation. Phase 2 Must Not be invoked in parallel with Phase 1, ahead of Phase 1, or as an override of a Phase 1 deny. Violation is a non-conformant variant per §4.6 (CCPE-F-NCO).

Verdict-vocabulary unification note. v0.9 uses a single three-value verdict enum {permit, deny, constrain} consistently across §2.5, §3.3, and §4.4. Obligations (e.g., sca_required, mfa_confirmation_above_threshold, phase2_unreachable, audit_persistence_required) are carried in a separate obligations: string[] array on the Decision Envelope. This aligns the wire contract with RFC 0117 §4.

Sequence diagram (informative):





2.6 Deployment Scenarios — S1 / S2 / S3 (Normative)

A CCPE-F-relevant deployment falls into one of three scenarios, all in scope of this RFC. The distinction between in-scope-of-RFC-0170 and conformant-to-G-Commerce is sharp and load-bearing for §4.5 (Conformance Checklist), §4.5a (Conformance by Scenario), and §4.6 (Non-Conformant Variants): scope is the broader set captured by the Foundation legal framework; conformance is the narrower set that meets the §4.5 bar. All three scenarios below are in-scope; only S2 is conformant to G-Commerce; S1 and S3 are non-conformant for the structural reasons given.

2.6.1 S1 — Pure Platform-Native Commerce Authorisation (no Foundation artefact)

Description. The vendor's native payment-authorisation surface alone: the agent presents a vendor-issued payment credential (a tokenised payment method, a setup-side mandate object, a platform-side agreement, an SCA-completed authorisation, a `paymentResponse`-equivalent) to the vendor's checkout / payment runtime; the vendor validates the credential against its own platform; the vendor's policy engine renders the authorisation decision. **No Foundation Commerce-Mandate envelope is constructed; no §4 UCP vendor-extension capability (`com.gimel.gauth.commerce_mandate`) is invoked; no §3.4 audit-event schema is emitted; the §2.5 Power-PEP → Commerce-PDP chain is not operated.** This is the

shape of essentially every production agent-to-vendor commerce deployment as of the v0.9.1 publication date.

Conformance status. S1 is non-conformant to G-Commerce at the §4.5 conformance bar. Each of the three §4.6 non-conformant variants (CCPE-F-NCI / NCP / NCO) is by default present in S1 because no compensating Foundation-side instrumentation exists: NCI because Phase 1 is absent; NCP because no §7.2 cascade is operated; NCO because the mandate → cart → payment phase-class chain is not preserved (the vendor's native artefact carries at most one of the three phase classes structurally).

Foundation IP touchpoints. None at the spec-implementation layer. S1 deployments may still touch Foundation IP at three indirect surfaces: (i) the Foundation's CCPE-F-NCI / NCP / NCO taxonomy when describing their non-conformance; (ii) the Foundation's Phase 1 / Phase 2 terminology when characterising their architectural posture; (iii) the Foundation's commerce-mandate and Commerce-PoA terms-of-art when classifying themselves.

Licensing posture. S1 deployments are subject to the Foundation legal / IPR framework for any descriptive use of Foundation-defined terms-of-art and taxonomies; they are not subject to the Apache 2.0 §3 patent grant of this RFC because they do not implement the specification's normative content. Vendors operating S1 deployments who wish to market against this RFC's normative bar Must not claim CCPE-F conformance and Must not claim G-Commerce conformance.

2.6.2 S2 — Two-Artefact via §4 UCP Vendor-Extension Capability (Recommended)

Description. The vendor's native payment-authorisation artefact continues to operate at Phase 2 unchanged; **a second Foundation-derived artefact** - the §3.1 Commerce-Mandate envelope, conforming to the GiFo-RFC 0115 PoA Credential structure - is carried over the Foundation-owned UCP vendor-extension capability `com.gimel.gauth.commerce_mandate` per §4. The two artefacts are operationally coupled at the Commerce-PEP boundary by the §2.5 Power-PEP → Commerce-PDP chain with more-restrictive-wins reconciliation. The mandate → cart → payment three-phase parent-chain (§3.1.1 phase-class binding, §3.1 `parent_mandate_id`) is structurally enforced at the Commerce-PEP; the §3.2 cascade is operated at the Authority; the §3.4 audit-event schema is emitted at every action.

Conformance status. S2 is the conformant scenario for G-Commerce. The §4.5 conformance checklist items are reachable in S2 and only in S2. The optional §9 Strict and Behörde badges are reachable in S2 only. None of the §4.6 non-conformant variants is structural to S2; an S2 deployment that nonetheless operates one of the variants (e.g., NCP by failing to operate §7.2 cascade) is a non-conformant S2 deployment,

distinguishable from S1 / S3 by the wire-level presence of the §3.1 envelope and `com.gimel.gauth.commerce_mandate` capability invocation.

Foundation IP touchpoints. S2 deployments touch all of: §3.1 (Commerce-Mandate envelope), §3.2 (Commerce-PoA lifecycle), §3.3 (Decision Envelope), §3.4 (audit-event schema), §3.5 (decision metering), §4 (UCP capability contract), §4.6 (variant taxonomy), §6 (cryptographic baseline), §9.1 (reservations catalogue), and the GiFo-RFC 0115 PoA Credential structure.

Licensing posture. S2 deployments are full implementers of this specification's normative content and are subject to the Apache 2.0 §3 patent grant of this RFC under the Legal Notice. The Foundation legal / IPR framework governs all Foundation-IP-bearing artefacts (§3.1 envelope, §3.4 audit schema, §3.5 metering hook, §4 UCP capability namespace, §4.6 variant taxonomy).

2.6.3 S3 — All-in-One Merged-Credential Deployment (vendor extends payment artefact with PoA-shape attributes)

Description. The vendor extends its native payment-authorisation artefact (a tokenised payment method, a setup-side mandate object, a platform-side agreement, an authorisation receipt) to carry PoA-shape attributes (`principal`, `mandate_class`, `parent_mandate_id`, `cap`, `vendors`, `expiry`, `delegation_chain`) **inside the same artefact body** rather than emitting a second Foundation-derived envelope. The artefact becomes a single hybrid carrying both the platform-bound payment authorisation and the PoA-shape claims; there is no second envelope, no §4 UCP vendor-extension capability invocation, and no §2.5 chain operation. Vendors May reach for S3 as a shortcut to "PoA-conformance" without operating the Foundation-side capability.

Conformance status. S3 is non-conformant to G-Commerce. The structural reasons are catalogued at §2.7 below (seven structural disadvantages, with the explicit non-conformance statement at §2.7.8): S3 does not resolve the architectural pattern that motivates the two-artefact split (the pattern is a governance-model property, not an artefact-format property — adding attributes to a single artefact does not fix it); S3 leaves the §3.4 audit-event schema unemitted (no `commerce.action_decided` event because no Commerce-PEP is operated); S3 collapses the §3.2 lifecycle separation between mandate and payment artefact into a single object whose mutation and revocation become entangled; and any wire-level immutability discipline adopted by S3 in lieu of the §4 capability invocation (per §2.7.7) is a Phase-2 artefact-discipline compensation for the absence of the principal-signed three-phase parent chain that S2 supplies structurally.

Foundation IP touchpoints. S3 deployments typically touch: the Foundation's Phase 1 / Phase 2 terminology (often misappropriated as "we cover both phases"); the Foundation's PoA-shape field names (`principal`, `mandate_class`, `parent_mandate_id`, `cap`, `delegation_chain`); the Foundation's CCPE-F-NCI / NCP / NCO taxonomy; and the Foundation's RFC 0115 PoA Credential field semantics.

Licensing posture. S3 deployments that adopt PoA-shape field names from RFC 0115, variant taxonomy values from §4.6, audit-trail semantics from §3.4, or §4 UCP capability-namespace conventions are subject to the Foundation legal / IPR framework regardless of their non-conformance to the §4.5 bar. In-scope of RFC 0170 ≠ conformant to G-Commerce: **S3 is in-scope for licensing capture and for normative critique, even though it cannot be declared G-Commerce conformant**.

Conditions under which S3 could approach conformance. If a vendor's S3 design (i) emits the §3.4 audit-event schema at every commerce-class action with persistence-before-stream; (ii) preserves a discrete principal-delegation event that the merged artefact cryptographically references via `principal_evidence`; (iii) honours the RFC 0115 §3.7 multi-hop scope-narrowing invariant across the mandate → cart → payment phase classes; (iv) preserves a discrete §3.2 cascade-revocation handle decoupled from the payment-artefact lifecycle so that revoking authority does not require revoking the payment credential; and (v) carries the artefact over `com.gimel.gauth.commerce_mandate` per §4 — then the deployment becomes effectively S2-by-another-name, and may be reclassified accordingly. Until all five conditions are met, S3 remains non-conformant to G-Commerce.

2.7 Single-Artefact Merged-Mandate Shortcut — Why the §4 UCP Capability Is Still Required (Normative)

A vendor may be tempted to treat the architectural argument for two artefacts as a credential-format problem and reach for the **S3 single-credential merged-attribute** scenario of §2.6.3 - extending its native payment-authorisation artefact body with PoA-shape claim fields and declaring victory. **This shortcut does not work**. The architectural pattern that motivates the two-artefact split is a **governance-model** property, not a **credential-format** property; adding fields to a single artefact body does not resolve any of the structural concerns. This subsection enumerates the **seven structural disadvantages** of S3 against the G-Commerce conformance bar and states the explicit non-conformance result at §2.7.8.

2.7.1 Cap-and-scope drift — authority-mutation observability is not native to S3

Shape. In S3, the merged artefact is signed at issuance time and carries the PoA-shape claims (`cap`, `vendors`, `category`, `expiry`) as static body fields. After issuance,

the principal's actual delegation surface continues to live at the Authority (per §2.4.b) and continues to mutate by Authority-side write — the principal raises or lowers the cap, narrows the vendor list, withdraws a category. The merged artefact's PoA claims now drift silently from the Authority's state until the artefact expires or is re-issued. **The freshness contract that §3.1.4 (parent-chain freshness bounds) requires is not native to S3** because S3's single-artefact design treats authority as an issuance-time snapshot, not as a continuously-Authority-evaluated surface. A downstream Phase-2 evaluator that accepts a stale merged artefact authorises an action the principal no longer permits; S2's §3.1.4 ceiling closes this gap by requiring a fresh parent-chain check at every action, with `parent_chain_invalid` emitted as an obligation when the bound is exceeded. **S3 deployments inherit cap-and-scope drift as a structural vulnerability**.

2.7.2 Missing discrete principal-delegation event — CCPE-F-NCO is structural in S3

Shape. §4.6.c (CCPE-F-NCO) classifies deployments where the mandate → cart → payment phase-class chain is not preserved. S3's merged artefact typically asserts a `principal` claim at artefact-issuance time on the vendor's onboarding workflow (the vendor's own admin or checkout process created the artefact); there is no discrete recorded principal-delegation event separate from the artefact issuance. §3.1's `principal_evidence` carry-through field, which records the issuance-side actor when the principal is administrator-asserted, has no audit-trail anchor in S3 because the artefact and the asserted principal-relationship are conflated into a single signed object. **S3 deployments are CCPE-F-NCO by default and cannot be reclassified upward without separating the principal-delegation event from the artefact-issuance event** - at which point the deployment has effectively reached for the §4 capability structure and become S2.

2.7.3 Three-phase parent-chain semantics absent — mandate → cart → payment cannot be enforced inside one artefact

Shape. §3.1 mandates that `cart`-class and `payment`-class envelopes carry a `parent_mandate_id` referencing a live (issued, not expired, not revoked) parent of the immediately-preceding class; §3.1.1 phase-class binding mandates that the chain be evaluated at the Commerce-PEP at every action; RFC 0115 §3.7 mandates scope narrowing along the chain. S3's single-artefact design has no native chain primitive: a cart-phase and payment-phase action, in S3, are typically evaluated against the same merged artefact whose claims were signed once at issuance time, with no per-phase signed envelope to bind the chain. The narrowing invariant of RFC 0115 §3.7 cannot be cryptographically enforced across S3 phase transitions because each phase does not carry an independent envelope with chain-binding cryptographic material. **S3**

deployments cannot honour mandate → cart → payment scope-narrowing at the artefact layer; the §4 capability layer is the only place where the three-phase chain can be enforced.

2.7.4 Lifecycle entanglement — §3.2 cascade-revocation unreachable

Shape. S2 separates the artefact lifecycle (Phase 2, vendor-side, governed by the vendor's own token / agreement / authorisation TTL) from the authority lifecycle (Phase 1, Authority-side, governed by §3.2 Commerce-PoA cascade). S3 collapses the two: revoking the merged artefact revokes both the payment-credential validity and the asserted authority simultaneously; revoking authority alone (e.g., the principal withdraws the mandate but the underlying payment credential remains valid for non-agent use) requires re-issuing the artefact, which is a heavier operation than an Authority-side cascade emission. The §3.2 invariant — that revoking a parent mandate cancels all in-flight platform-side artefacts (PaymentIntents, ChargePermissions, carts) — cannot be operated when there is no separable parent mandate to revoke against. **S3 deployments cannot independently revoke authority while preserving the payment credential**, and cannot operate §3.2 cascade at all — a cardinal property of the Phase-1 / Phase-2 separation that the §4 capability preserves and that the §4.5 conformance bar requires.

2.7.5 Cross-vendor interoperability break — vendor-specific wire format

Shape. S2's Commerce-Mandate envelope conforms to the GiFo-RFC 0115 PoA Credential structure and is carried over the Foundation-owned `com.gimel.gauth.commerce_mandate` UCP capability per §4; the same envelope shape and the same capability namespace are honoured across every vendor. A CCPE-F downstream consumer (an aggregator, an audit pipeline, a regulator-bound export per §13) can validate the envelope without per-vendor knowledge. S3's merged artefact is a vendor-specific wire format — every vendor extends its own native artefact in its own way; there is no shared shape, no shared capability namespace, no shared validator. A CCPE-F downstream consumer cannot validate S3 artefacts without a vendor-specific parser, and cross-vendor portability of the principal's mandate (the ability to take the same Commerce-Mandate to Vendor A and Vendor B) is lost. **S3 breaks cross-vendor interoperability** - the very property the §4 single normative integration scenario is designed to preserve. Each vendor's S3 wire format becomes a per-vendor balkanisation of the commerce-mandate layer, defeating the cross-vendor interoperation goal that motivates the §4 architecture.

2.7.6 Governance-model versus credential-format — the category error

Shape. The architectural pattern that motivates the §3.1 envelope plus the §4 UCP capability is a property of the **governance model** - how authority is recorded, mutated, narrowed, revoked, evidenced, and bridged across deployment boundaries — not a property of the **artefact format**. Authority-mutation observability (§2.7.1) is a property of where authority lives, not what shape the artefact takes. Three-phase chain enforcement (§2.7.3) is a property of how the mandate → cart → payment delegation chain is recorded and enforced, not what fields the artefact carries. Cascade-revocation (§2.7.4) is a property of which lifecycle the revocation operates on, not what the wire-level artefact carries. **Adding PoA-shape attributes to a single artefact body does not change the governance model; it only encodes a snapshot of the governance model at artefact-issuance time.** The §4 capability changes the governance model by introducing a discrete Foundation-instrumented evaluation step that re-evaluates the Authority at every action; S3 cannot reach that change by artefact-format alone.

2.7.7 Phase-2 artefact-discipline cannot supply Phase 1 — wire-level invariants on a single artefact do not substitute for the principal-signed parent chain

Shape. A pattern observed in S3 single-artefact merged-attribute deployments is the introduction of a wire-level **immutability discipline** on the merged artefact: the artefact is signed at issuance time, and a downstream Phase-2 authorisation-server discipline mandates that selected fields (typically the agent identity binding and the asserted PoA-shape claims) Must Be preserved unchanged across any token-exchange, re-issuance, or narrowing step. The intent is to give the Phase-2 authorisation server a per-action handle on "the same agent identity and the same asserted authority that the principal originally delegated" — a property that single-artefact designs otherwise lose between issuance and re-use across multi-step commerce flows.

Why the discipline is needed in S3. In S3, the merged artefact is the only object that carries both the payment-credential binding and the asserted PoA-shape claims; after issuance, neither the vendor nor the principal-side Authority has any independent record of the principal-to-agent delegation that motivated the artefact - the artefact is the record. Any rewriting step (cart-side modification, payment-side narrowing, downstream re-issuance) therefore risks substituting the asserted authority silently. The Phase-2 immutability discipline is S3's structural compensation: a wire-level rule imposed on artefact-rewriting parties that the original asserted claims Must Not Be replaced.

Why the discipline is structurally unnecessary in S2 (and why the §4 capability resolves the underlying problem more cleanly). The S2 §3.1 envelope does not require an artefact-rewriting discipline because the **envelope is signed by the principal** (or by the principal's authorised delegation actor, recorded as `principal_evidence` per §3.1) and **carries a cryptographic narrowing chain** per RFC 0115 §3.7, with each phase's envelope binding back to its parent via `parent_mandate_id`. The narrowing is achieved **structurally** in S2 — not by a downstream-discipline invariant on artefact-rewriting parties, but by the §3.1 envelope's own per-phase signature and by the chain-binding cryptographic material that links each hop's envelope to its predecessor. The downstream Commerce-PEP does not have to **trust** that intermediate parties preserved any field; the Commerce-PEP *verifies* the chain itself via the principal's signature and the per-phase narrowing material at §3.1.4 freshness ceilings. **Where S3 needs an external discipline to substitute for the chain, S2 has the chain**.

The category error, restated. A wire-level invariant on a single artefact body cannot substitute for a governance-architecture property that lives in the principal-signed delegation chain. S3's immutability discipline is a compensation for the **absence** of the §4 capability, not an **alternative** to it. Phase-2 artefact-handling discipline is necessary for artefact-handling integrity but is not sufficient for PoA-grade subject and scope continuity across the mandate → cart → payment phase boundaries. A vendor that adopts the discipline in an S3 deployment Has improved S3's robustness against *one* class of artefact-rewriting attack but Has not closed any of the §2.7.1–§2.7.6 disadvantages and Has not crossed the §2.6.3 five-condition bar to S2-by-another-name; the deployment remains non-conformant to G-Commerce.

2.7.8 Explicit non-conformance statement

S3 is non-conformant to G-Commerce and Must not be declared at the §4.5 conformance bar - regardless of whether an S3 deployment additionally adopts a Phase-2 artefact-immutability discipline per §2.7.7 or any other Phase-2 credential-discipline compensation. Vendors operating S3 deployments who wish to claim G-Commerce conformance Must implement the §4 UCP vendor-extension capability `com.gimel.gauth.commerce_mandate` and the §3.1 envelope shape — at which point, by the conditions enumerated at §2.6.3, the deployment becomes S2 by another name and the conformance assessment proceeds against the §4.5 checklist. **The §4 capability is not a sidecar that S3 obviates; it is the central operational mechanism that S3 cannot reach by extending the payment artefact alone, and that wire-level immutability disciplines (§2.7.7) compensate for only at the artefact-rewriting integrity layer, not at the governance-architecture layer.**

3. Normative Concepts

3.1 Commerce Mandate

A Commerce Mandate is a Power-of-Attorney credential (per RFC 0115) whose payload is specialised for the commerce-authorization domain.

Field-level normative table — top-level fields:

Field Type Required Constraints Notes

mandate_id URI Required Deployment-unique §3.1

mandate_class enum Required mandate | cart | payment Reserved §9.1

parent_mandate_id URI Required for cart/payment; Must Not be present for mandate-class References a live (issued, not expired, not revoked) parent mandate of the immediately-preceding class §3.1.1

principal object Required subject Required; tenant Optional §3.1

agent object Required subject + agent_runtime Required §3.1

vendor_scope object Required At least one of allowed_vendors / allowed_marketplaces non-empty §3.1

commerce_constraints object Required See sub-table below §3.1

payment_constraints object Required for payment class; Optional otherwise See sub-table below §3.1

validity object Required not_before ≤ not_after; single_use Required (default false); single_use Must be true for payment class §3.1.3

fail_disposition enum Required fail_closed | fail_drop_payment_only §2.5.c

phase2_timeout_ms integer Required 1–10000 ms; subject to profile ceiling §3.1.5 §3.1.5

audit_correlation object Required trace_id Required; mandate_correlation Required for cart/payment §3.4

issuer object Required authority, issued_at (RFC 3339), kid (RFC 7517) all Required §6.1, §6.7

signature	string	Required	JWS per RFC 7515 over the §6.2-canonicalised remainder	§6.1, §6.2

commerce_constraints sub-fields:

Field	Type	Required	Constraints	Notes
currency	string	Required	ISO 4217 alpha-3	§3.1
amount_cap	decimal-string	Required	Decimal in minor units (e.g. cents) as a string. Strings are used to preserve exact decimal arithmetic; JSON numbers are not permitted to avoid IEEE-754 rounding loss.	§3.1
amount_cap_period	enum	Required	single | daily | weekly | monthly	§3.1
item_category_allowlist	array	Optional	Empty array means "no allowlist constraint"; absence means "no constraint"	§3.1
item_category_denylist	array	Optional	Denylist evaluated after allowlist	§3.1
commerce_intent	string	Optional	Non-normative; free-text. Must Not be used as a verdict-determining input.	§3.1
platform_evidence	object	Optional	Opaque carry-through; CCPE-G bridge-inbound use-case at §5.1	v0.8 §1.2.d

payment_constraints sub-fields:

Field	Type	Required	Constraints	Notes
payment_method_allowlist	array	Required for payment class	Tokenised method identifiers	§3.1
payment_account_scope	array	Required for payment class	Tokenised account references; Must Not contain PAN material per §6.6	§6.6
rail_allowlist	array	Optional	Rail identifiers (e.g. SEPA, ACH, card-rail)	§3.1
mfa_confirmation_required_above	object	Optional	currency (ISO 4217) + value (decimal-string in minor units). Both jurisdiction-dependent; see Appendix D.1. The example value {"currency":"EUR","value":"3000"} (€30) is illustrative only and Must Not be read as a fixed default.	§D.1, v0.8 §1.2.e

Illustrative envelope:

```
{
  "mandate_id":          "<URI reference, deployment-unique>",
  "mandate_class":       "mandate" | "cart" | "payment",
  "parent_mandate_id":   "<URI reference; Required for cart
and payment classes>",
  "principal": {
    "subject":           "<principal subject identifier>",
    "tenant":            "<tenant identifier; Optional>"
  },
  "agent": {
    "subject":           "<agent subject identifier>",
    "agent_runtime":     "<runtime identifier>"
  },
  "vendor_scope": {
    "allowed_vendors":              ["<vendor identifier>",
"..."],
    "allowed_marketplaces":         ["<marketplace
identifier>", "..."],
    "vendor_jurisdiction_allowlist":["<ISO 3166-1 alpha-2>",
"..."]
  },
  "commerce_constraints": {
    "currency":          "<ISO 4217 alpha-3>",
    "amount_cap":        "<decimal string in minor units>",
    "amount_cap_period": "single" | "daily" | "weekly" |
"monthly",
    "item_category_allowlist": ["<category identifier>",
"..."],
    "item_category_denylist":  ["<category identifier>",
"..."],
```

```
    "commerce_intent":   "<free-text non-normative
description>",
    "platform_evidence": { /* Optional opaque carry-through;
see §5.1 */ }
  },
  "payment_constraints": {
    "payment_method_allowlist": ["<method identifier>",
"..."],
    "payment_account_scope":    ["<tokenised account
reference>", "..."],
    "rail_allowlist":           ["<rail identifier>", "..."],
    "mfa_confirmation_required_above": {
      "currency":        "<ISO 4217 alpha-3; jurisdiction-
dependent per Appendix D.1>",
      "value":           "<decimal string in minor units;
jurisdiction-dependent per Appendix D.1>"
    }
  },
  "validity": {
    "not_before":        "<RFC 3339 timestamp>",
    "not_after":         "<RFC 3339 timestamp>",
    "single_use":        true | false
  },
  "fail_disposition":    "fail_closed" |
"fail_drop_payment_only",
  "phase2_timeout_ms":   1500,
  "audit_correlation": {
    "trace_id":          "<deployment-unique trace
identifier>",
    "mandate_correlation": "<reference to mandate-phase
mandate; for cart and payment classes>"
  },
  "issuer": {
```

```
    "authority":          "<Authority identifier>",
    "issued_at":          "<RFC 3339 timestamp>",
    "kid":                "<key identifier per RFC 7517>"
  },
  "signature":            "<JWS per RFC 7515 over the §6.2-
canonicalised payload>"
}
```

Phase-class binding. mandate_class ∈ {mandate, cart, payment}. A mandate-class mandate Must Not carry parent_mandate_id; a cart-class or payment-class mandate Must carry parent_mandate_id referencing a live mandate-class or cart-class mandate respectively.

Phase-order chain. A payment-class mandate's parent_mandate_id Must reference a cart-class mandate; that cart-class mandate's own parent_mandate_id Must reference an mandate-class mandate. The Commerce-PDP Must verify the full chain at every Phase 1 / Phase 2 reconciliation.

Forward-compatibility envelope. Implementations Must accept additional fields not defined in v0.9 without rejecting the mandate. Implementations Must Not introduce fields whose presence changes the meaning of any v0.9-defined field.

The commerce_intent field is non-normative; verdict determination relies on the structured fields.

3.1.1 Phase-Class Binding

A payment-class mandate is single-use and Must be derived (via parent_mandate_id) from a cart-class mandate which is in turn derived from an mandate-class mandate. The Commerce-PDP at Phase 2 Must verify the full chain at every Phase 1 / Phase 2 reconciliation. A child mandate whose declared parent_mandate_id resolves to a revoked, expired, or class-incompatible parent Must be rejected at Phase 1 with verdict deny and obligation parent_chain_invalid.

3.1.2 Constraint-Subset Rule

The commerce_constraints and payment_constraints of a child mandate Must be subsets of the parent's. Tightening permitted; loosening prohibited.

3.1.3 Single-Use Payment Class

A payment-class mandate is consumed at the first Phase-2 successful invocation. The Commerce-Runtime Must reject any subsequent invocation referring to a consumed payment mandate with verdict deny and obligation mandate_already_consumed.

3.1.4 Parent-Chain Freshness Bounds

The Commerce-PDP at Phase 1 / Phase 2 reconciliation Must read the parent-mandate-state from Authority subject to a profile-dependent staleness ceiling:

Profile Parent-mandate-state staleness Notes

Default (commerce-default) ≤ 5 s Polled introspection acceptable

Strict (commerce-strict) (reserved §9) ≤ 1 s Push notification or sub-second polling

Behörde (commerce-behoerde) (reserved §9) ≤ 1 s Audit-bound-time-source attestation Must accompany the introspection record

A staleness exceedance Must be treated as phase2_unreachable per §2.5.c.

3.1.5 Phase-2 Timeout Declaration

phase2_timeout_ms carries the deployment-declared Phase-2 timeout, measured from the moment the Commerce-PEP issues the §4.3 capability invocation to the moment a verdict envelope is fully received (HTTP body complete) at the Commerce-PEP. Wall-clock measured from the Commerce-PEP's monotonic clock.

3.1.6 Profile Parameters Table (Normative)

Parameter Anchor Default Strict (reserved) Behörde (reserved) Measurement method

phase2_timeout_ms §3.1.5 1500 ms ≤ 750 ms ≤ 500 ms From Commerce-PEP request-issued to verdict-fully-received; Commerce-PEP monotonic clock

Parent-mandate-state staleness §3.1.4 ≤ 5 s ≤ 1 s ≤ 1 s + audit-bound time-source attestation From Authority mandate_state.observed_at to Commerce-PEP reconciliation-record evaluated_at; same wall-clock domain

Cascade-revocation latency §7.2 ≤ 5 s ≤ 1 s ≤ 1 s From Authority commerce.cascade.requested.emitted_at to

first downstream commerce.cascade.revoked.emitted_at per affected vendor; Console wall-clock

Audit persistence ack §3.4 ≤ 250 ms ≤ 100 ms ≤ 100 ms From Commerce-Runtime event-emit to Console event-store fsync ack

Replay clock-skew window §6.8 ± 60 s ± 10 s ± 5 s issued_at vs verifier wall-clock

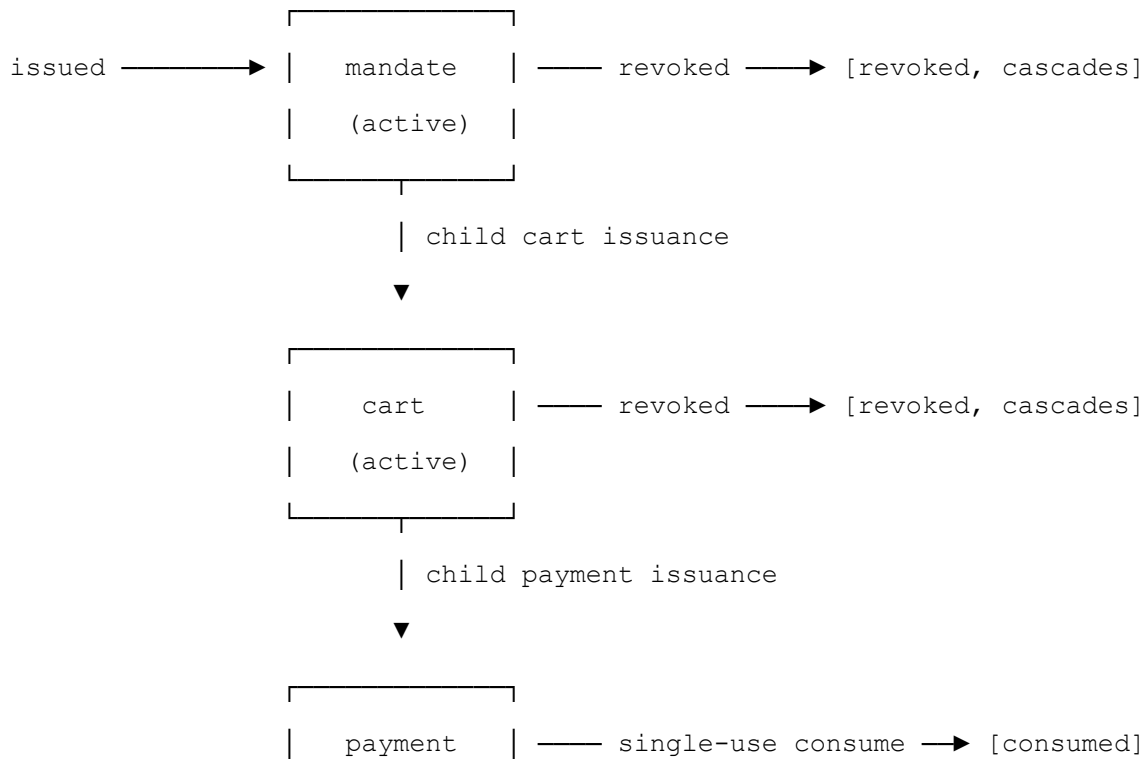
Authority signing-key rotation §6.4 ≤ 365 d ≤ 90 d ≤ 30 d From kid first-use to kid retirement

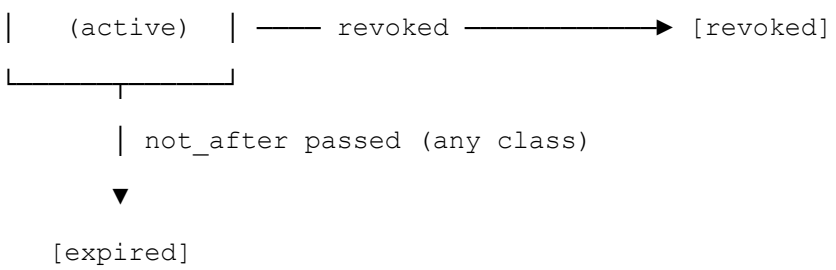
All profile-parameter measurements are subject to the Console's audit-bound time-source for the persistence-before-stream invariant per §3.4.

3.2 Commerce Power-of-Attorney (Commerce-PoA)

A Commerce-PoA is the lifecycle aggregation of an mandate-class, cart-class, and payment-class mandate under a shared audit_correlation.trace_id and shared parent chain. Cascade-revocation: revocation of any mandate in the chain Must revoke every descendant mandate and emit commerce.cascade.revoked per descendant. Budget-aggregation: every descendant's commerce_constraints.amount_cap is bounded above by the closest non-null ancestor cap and below by the sum of any sibling already-consumed amounts.

Mandate-chain state diagram (informative):





A revocation of the mandate-class mandate cascades to cart and payment; a revocation of cart cascades to payment; a revocation of payment is local. Cascade traversal Must complete within the §3.1.6 cascade-revocation latency budget.

3.3 Commerce-PEP and the Decision Envelope

The Commerce-PEP at Phase 1 produces a Decision Envelope:

```
{
  "verdict":     "permit" | "deny" | "constrain",
  "obligations": [
    "sca_required",
    "mfa_confirmation_above_threshold",
    "phase2_unreachable",
    "audit_persistence_required",
    "parent_chain_invalid",
    "mandate_already_consumed"
  ],
  "phase":       "phase1",
  "trace_id":    "<W3C trace-id>"
}
```

Verdict semantics:

- permit — the action is authorized. An empty obligations array means unconditionally permitted. A non-empty obligations array means permitted subject to the listed obligations being honoured by the caller.
- deny — the action is refused. The obligations array carries the diagnostic reason codes.

- constrain — the action is permitted in narrowed form. The obligations array carries the constraint instructions.

The set of obligation strings is reserved at §9.1.

3.4 Commerce Audit Trail

Event type	When
commerce.action_proposed	Phase 1 invoked
commerce.action_decided	Phase 1 verdict produced
commerce.platform_bound.invoked	Phase 2 invoked
commerce.platform_bound.decided	Phase 2 verdict received
commerce.platform_bound.failure	Phase 2 unreachable / errored / mismatch
commerce.cascade.revoked	Authority-side mandate revocation cascaded to vendor
commerce.decision.metered	A CommerceDecisionMeteringRecord was produced

Persistence-before-stream invariant. Audit events Must be persisted at the Console event store before any out-of-process streaming subscriber is notified.

3.5 Commerce Decision Metering and Open-Core Symmetry

Two-Hats Footnote. This §3.5 metering hook is a Foundation-specified protocol contract that applies to every operator emitting commerce.decision.metered events. The downstream billing fact — whether and how an emitted record produces a charge against any operator — is governed by separate Gimel Technologies commercial agreements and is out of scope of this RFC. See §1.5.e.

3.5.1 Metering Record

Every Phase-2 capability invocation per §4.3 Must produce a CommerceDecisionMeteringRecord:

```
{
  "mandate_id":      "<URI>",
  "vendor_id":       "<platformId from §4.2 registration>",
```

```
  "mandate_class":    "mandate" | "cart" | "payment",
  "phase":            "phase1" | "phase2",
  "tariff_tier":      "O" | "S" | "M" | "L",
  "operator_mode":    "gimel_managed" | "user_self_hosted",
  "billable":         true | false,
  "reason":           "<explanatory string>",
  "emitted_at":       "<RFC 3339 timestamp>"
}
```

Footnote on tariff_tier. The O / S / M / L enum values are placeholders whose semantics are defined in the Gimel Technologies open-core commercial schedule and are out of scope of this RFC.

3.5.2 Open-Core Symmetry Invariants

Three invariants Must hold on every metering record:

a) Unknown-vendor fail-closed. If vendor_id does not correspond to a registered Commerce-PDP instance, the metering call Must throw a fail-closed error and Must Not silently default to non-billable. Silent defaulting would create a billing-integrity hole.
b) user_self_hosted is never billable. Where the Commerce-PDP instance was registered with operator_mode = "user_self_hosted", billable = false regardless of tariff tier.
c) Tariff-O coerces non-billable. Where tariff_tier = "O" (open-core), billable = false regardless of operator_mode. A gimel_managed instance metered at Tariff O Must produce a warning log advising the operator to reconcile by unregistering and re-registering as user_self_hosted.

3.5.3 Audit Tie-In

Every traversal of the metering hook Must emit a commerce.decision.metered audit event into the unified GAuth audit JSON stream alongside the existing commerce.action_* events.

4. Single Normative Integration Scenario — G-Commerce via UCP-Mediated Mandate Carriage

4.1 Architectural Placement

CCPE-F specifies a single normative integration scenario operating over the UCP substrate and the Foundation-owned vendor-extension capability com.gimel.gauth.commerce_mandate. A deployment-defined direct-transport variant remains non-normative.

4.2 Capability Resolution via /.well-known/ucp

```
{
  "capabilities": [{
    "name":         "com.gimel.gauth.commerce_mandate",
    "version":      "1.0",
    "endpoint":     "https://<deployment>/commerce-pdp/v1",
    "auth_scheme": "hmac-dual-auth"
  }]
}
```

4.3 Capability Endpoint Contract

POST requests carry the proposed action, the Commerce-Mandate envelope, and the trace context. Responds with the §4.4 verdict envelope. Transport per §6.3.

4.4 Mandate-Carriage Payload (Verdict Envelope, Phase 2)

```
{
  "verdict":      "permit" | "deny" | "constrain",
  "obligations": ["..."],
  "phase":        "phase2",
  "phase2": {
    "platform_evidence": { /* opaque platform-side evidence
blob */ }
  },
  "trace_id":     "<W3C trace-id>"
}
```

The Phase-2 verdict envelope uses the same three-value verdict enum and the same obligations array shape as the Phase-1 envelope at §3.3, ensuring uniform reconciliation semantics at §2.5.c.

4.5 Conformance Checklist

A deployment claims G-Commerce Conformance if and only if it satisfies:

- §2.4 three-service pattern (no role conflation);
- §2.5 Power-PEP → Commerce-PDP chain operated for every commerce-class action;
- §3.1 envelope shape (including platform_evidence carry-through admitted);
- §3.1.4 freshness ceiling for the active profile;
- §3.3 Decision Envelope vocabulary ({permit, deny, constrain} + obligations array);
- §3.4 audit stream emission with persistence-before-stream;
- §3.5 metering-hook emission with all three §3.5.2 invariants;
- §4 UCP capability discovery and endpoint contract;
- §6 cryptographic baseline (incl. §6.2 canonicalisation, §6.3 transport, §6.6 PAN-carriage prohibition).

4.5a Conformance by Deployment Scenario (S1 / S2 / S3)

The §2.6 deployment scenarios map to the §4.5 conformance bar as follows. **In-scope of RFC 0170 ≠ conformant to G-Commerce**. All three scenarios are in-scope of this RFC for licensing-capture and normative-critique purposes; only S2 is conformant to G-Commerce.

```
| Scenario (per §2.6) | G-Commerce conformant | CCPE-F Strict (§9) | CCPE-F Behörde (§9) | Default §4.6 variants present | Reason for non-conformance (where applicable) |
|---|---|---|---|---|---|
| **S1 — Pure Platform-Native** | **Non-conformant** | **Non-conformant** | **Non-conformant** | NCI + NCP + NCO by default | No §3.1 envelope; no §4 UCP capability invocation; no §2.5 chain operation; no §3.4 audit-event schema; no §3.2 cascade. |
| **S2 — Two-Artefact via §4 Capability** | **Conformant** | Reachable | Reachable | None structural; per-deployment variants possible | — |
```

```
| **S3 — Merged-Credential** | **Non-conformant** | **Non-conformant** | **Non-conformant** | NCO structural; NCI / NCP typically present | §2.7 seven structural disadvantages; the §4 capability is unreachable by extending the payment artefact alone; any §2.7.7 immutability discipline is a Phase-2 compensation, not a substitute. |
```

Determination procedure. A G-Commerce Conformance Statement **Must** name (i) the deployment's scenario per §2.6 (S1 / S2 / S3); (ii) the per-item disposition against the §4.5 checklist; (iii) the applicable §4.6 variant codes (if any); (iv) the audit-trail evidence supporting (i)–(iii). The audit-trail field `ccpe_f_scenario` (reserved per §9.1) carries the scenario value on the wire.

Cross-validation. A §4.5-checklist determination of *conformant* combined with a §2.6 scenario of S1 or S3 **Is rejected** by the Conformance Statement reviewer; the deployment **Must** either (a) move to S2 by operating the §4 UCP capability and emitting the §3.1 envelope, or (b) restate its scope so that the conformance claim is explicitly limited to the §4.6 non-conformant variant register.

4.6 Non-Conformant Variants — CCPE-F-NCI / NCP / NCO

a) CCPE-F-NCI — No Credential-bound Integration. Deployment runs Phase 2 only; Phase 1 absent. Audit-tag prefix ccpe-f-nci-*.
b) CCPE-F-NCP — No Cascade-revocation Propagation. Phase 1 + Phase 2 but no §7.2 cascade. Audit-tag prefix ccpe-f-ncp-*.
c) CCPE-F-NCO — No Conformant-Order Preservation. Deployment performs Phase 1 / Phase 2 but does not preserve the mandate → cart → payment phase-class chain. Audit-tag prefix ccpe-f-nco-*.

Scenario-thread. S1 deployments (§2.6.1) carry CCPE-F-NCI + CCPE-F-NCP + CCPE-F-NCO by default because no §3.1 envelope, no §7.2 cascade, and no phase-class chain are operated. S3 deployments (§2.6.3) carry CCPE-F-NCO structurally per §2.7.3 (the chain cannot be enforced inside a single artefact) and typically carry CCPE-F-NCI and CCPE-F-NCP because no §2.5 Phase-1 evaluator and no §7.2 Authority-side cascade are operated against a separable mandate. S2 deployments (§2.6.2) do not carry any §4.6 variant structurally; an S2 deployment that nonetheless operates one of the variants is a non-conformant S2 deployment whose specific variant is recorded in the audit trail.

Footnote. The NCI / NCP / NCO acronyms are profile-local. Their CCPE-G counterparts in RFC 0210 §3.4 carry different expansions. The two profiles' non-conformant variants are unambiguously distinguished on the wire by the ccpe-f-* versus ccpe-g-* audit-tag prefix; consumers Must Not parse the bare three-letter acronym out of context.

5. Concept Mapping — GAuth/CCPE ↔ UCP (Informative)

GAuth/CCPE concept UCP concept

Commerce-Mandate envelope (§3.1) UCP capability invocation payload

mandate_class (§3.1) UCP intent_phase discriminator

Phase-1 verdict envelope (§3.3) UCP pre-flight evaluation result

Phase-2 verdict envelope (§4.4) UCP capability response

Commerce-Runtime (§2.1) UCP capability consumer

Commerce-PDP (§2.4) UCP capability provider

Cascade-revocation pipeline (§7.2) UCP capability lifecycle hook

5.1 CCPE-G Bridge Inbound (Informative)

CCPE-G concept (RFC 0210) CCPE-F concept

SyntheticMandateEnvelope (RFC 0210 §6.1) emitted at trigger commerce_class_action (RFC 0210 §6.2.c) Inbound Commerce-Mandate envelope at the CCPE-F Commerce-PEP

BridgeEvidence (RFC 0210 §6.1.4) commerce_constraints.platform_evidence carry-through field at Phase 1

Bridge-side variantCode (RFC 0210 §3.4) Reflected into the §3.4 audit event as ccpe_g_inbound_variant

A CCPE-G synthetic Commerce-Mandate emitted at RFC 0210 §6.2(c) is a first-class inbound to the CCPE-F Commerce-PEP and Must be processed identically to an Authority-issued Commerce-Mandate, modulo the ccpe_g_inbound_variant audit annotation.

6. Cryptographic Requirements

6.1 Signature Algorithms

The Commerce-Mandate signature field Must use a signature algorithm permitted by RFC 0115 §5.4, applied as a JWS per RFC 7515 over the §6.2-canonicalised payload. Within the RFC 0115 set:

Algorithm CCPE-F preference Rationale

```
EdDSA (Ed25519)    Recommended    Constant-time verification,
minimal envelope footprint, parity with RFC 0115 §5.4(a)

ECDSA (ES256)  Acceptable    Universal availability in payment
HSMs; parity with RFC 0115 §5.4(b)

RSA-PSS   Permitted, deprecated   Carried for legacy Authority
deployments only
```

Profile-specific overrides:

- Behörde (reserved): EdDSA Required; ES256 acceptable only with HSM-bound key attestation.
- Strict (reserved): EdDSA Recommended; RSA-PSS not permitted.

The kid header parameter Must reference a key published in Authority's JWKS endpoint per RFC 7517.

6.2 Canonicalisation

Every signed mandate body and every HMAC-signed cross-service request body Must be canonicalised per RFC 8785 (JSON Canonicalization Scheme, JCS) prior to signature computation. The §6.1 JWS signs the canonicalised payload bytes, not the wire-form payload bytes. Implementations that Do Not canonicalise prior to signature Must Not be considered conformant.

The canonicalisation step is the normative anchor that two independent implementations Must agree on the exact byte sequence under signature; absent this anchor, structurally-equivalent JSON encodings (key-ordering, whitespace, number-form) would produce divergent signatures and break cross-implementation verifiability.

6.3 Transport

All Console ↔ Authority, Console ↔ Commerce-Runtime, Authority ↔ Commerce-Runtime, and Commerce-PEP ↔ Commerce-PDP traffic Must use TLS 1.3 or higher. Mutual authentication is Required where both peers present TLS client certificates issued under a deployment-controlled CA; this applies in particular to the §4.3 Phase-2 capability invocation between the Commerce-PEP and the vendor-side Commerce-PDP where the Commerce-PDP is co-deployment-operated.

Where the Commerce-PDP is operated by a counterparty whose TLS posture the deployment does not control, the deployment Must record the negotiated TLS profile

(version, cipher suite, peer certificate fingerprint) into the §3.4 commerce.platform_bound.invoked audit event for post-hoc verifiability.

6.4 Key Rotation

Authority signing keys Must rotate at least every 365 days; Strict reserves 90 days; Behörde reserves 30 days per §3.1.6. Old keys remain in the JWKS endpoint for verification of in-flight mandates until all such mandates have expired.

Key rotation bounds the blast radius of a signing-key compromise only; it is not the mechanism for cancelling legitimately-issued mandates. Mandate cancellation is governed by Authority-side revocation with cascade propagation per §7.2 and introspection per RFC 0118, and is independent of the key-rotation cycle.

6.5 Audit Signature

commerce.cascade.revoked events Must carry an Authority signature.

6.6 PAN-Carriage Prohibition (Normative Anchor)

The Commerce-Mandate envelope Must Not carry a Primary Account Number (PAN) or any other PCI-DSS-scoped cardholder-data element. Payment instruments are referenced exclusively by tokenised reference (payment_constraints.payment_account_scope).

6.7 Trace-Context Binding

Every signed envelope Must bind the W3C Trace Context trace_id into the signed payload.

6.8 Replay Defence

Authority-issued envelopes Must carry monotonic issued_at. Verifiers Must reject envelopes outside a deployment-declared clock-skew window (default ± 60 s; Strict ± 10 s; Behörde ± 5 s per §3.1.6).

6.9 PQC Migration

Deferred until the GAuth credential-layer RFCs (0115 / 0116 / 0117) themselves migrate.

7. Security Considerations

7.1 Threat Model Summary

The CCPE-F threat surface comprises: (a) credential forgery / replay against the Power-PEP; (b) platform-side policy bypass against the Commerce-PDP; (c) phase-order violation (CCPE-F-NCO); (d) cascade-revocation omission (CCPE-F-NCP); (e) audit-trail tampering at Console; (f) Authority signing-key compromise; (g) substrate-governance drift (see §7.10); (h) canonicalisation drift between implementations causing signature non-verification (mitigated at §6.2); (i) TLS-profile drift on counterparty-operated Commerce-PDP (mitigated at §6.3).

7.2 Cascade-Revocation Latency

Default cascade completion Should be ≤ 5 s; Strict reserves ≤ 1 s; Behörde reserves ≤ 1 s. Measurement method per §3.1.6.

7.3 Replay Defence

Per §6.8.

7.4 Audit-Trail Integrity

Console event-store Must be append-only with verifiable hash-chain per RFC 0160. The persistence-before-stream invariant (§3.4) prevents downstream-streaming-subscriber observations of events that have not yet committed at Console.

7.5 Key-Compromise Recovery

Authority key-compromise Must trigger immediate cascade revocation of every mandate signed under the compromised kid and a §3.4 commerce.cascade.revoked per affected mandate.

7.6 PAN-Carriage Prohibition

Per §6.6 (normative anchor).

7.7 Intentionally left blank

-

7.8 Vendor-Side Fraud-Detection Out-of-Scope

Per §1.4.d. The Commerce-PDP's Phase 2 verdict is the deployment's contractual interface to vendor-side risk; CCPE-F does not constrain how the vendor reaches that verdict.

7.9 Trust-Boundary Conflations

Per §2.4 trust-boundary diagram. Conformance audits Must verify that no two of {Console, Authority, Commerce-Runtime} share the same operational identity, signing key, or persistence layer.

7.10 Substrate Governance (UCP Coupling)

§4 ties the single normative integration scenario to the Universal Commerce Protocol substrate, governed by the UCP Foundation. The Gimel Foundation is not a UCP Tech-Council member as of the v0.9 publication date. Risks:

a) Capability-namespace drift. A UCP non-backwards-compatible change to vendor-extension capability discovery or invocation conventions would break every CCPE-F deployment that has not yet migrated. Deployments Should subscribe to UCP-Foundation-published change notifications and Should maintain a documented migration-window posture.
b) Substrate-availability drift. A UCP discovery-service outage degrades to a §2.5.c Phase-2-unreachable condition for affected vendors; the mandate's fail_disposition controls the outcome.
c) Mitigation. §13.h tracks an alternative-substrate normative scenario for v1.0; until then, deployments Should keep the Commerce-PDP behind a substrate-neutral internal interface so that a future substrate switch is contained to the §4.2 / §4.3 layer.

8. References

8.1 Normative References

GiFo-RFC 0090 (Rights in Contributions); GiFo-RFC 0110 (GAuth Protocol Engine); GiFo-RFC 0111 (GAuth Authorization Framework); GiFo-RFC 0115 v2.2 (Power-of-Attorney Credential Definition); GiFo-RFC 0116 (Extended Token / W3C VC Representation); GiFo-RFC 0117 (PEP Interface); GiFo-RFC 0118 (Management API); GiFo-RFC 0160 (G-Audit Profile); GiFo-RFC 0180 v0.3 §14 (cross-Foundation Normative Technology Exclusions); BCP 14 (RFC 2119, RFC 8174); RFC 7515 (JWS); RFC 7517 (JWK); RFC 8785 (JSON Canonicalization Scheme, JCS) — normative anchor for §6.2; UCP — Universal Commerce Protocol v1.0.

8.2 Informative References

GiFo-RFC 0210 v0.7 (CCPE-G — bridge-inbound source per §5.1, no normative dependency); IETF RFC 2753 (Framework for Policy-based Admission Control — origin of Policy*Point); OASIS XACML 3.0; UCP Foundation Tech-Council Expansion Announcement (24 April 2026); EU Regulation (EU) 2024/1689 — EU AI Act; EU Directive (EU) 2015/2366 — PSD2; EBA RTS on SCA (Commission Delegated Regulation (EU) 2018/389); UK FCA Handbook; W3C Payment Request API Recommendation; PCI-DSS v4.0; Gimel Technologies open-core commercial schedule (informative anchor for the §3.5.1 tariff_tier enum semantics).

9. Conformance Levels and Reservations

A deployment claims G-Commerce Conformance if and only if it satisfies the §4.5 conformance checklist in full. The §4 integration scenario is the single normative integration scenario under v0.9.

A deployment is non-conformant to G-Commerce if it operates any of the §4.6 CCPE-F-NCI / NCP / NCO variants.

Two additional optional badges are reserved for v1.0:

- CCPE-F Strict (reserved) — adds the ≤ 1 s revocation-tolerance ceiling on §7.2 cascade; the ≤ 1 s parent-chain-state staleness per §3.1.4; the ≤ 750 ms phase2_timeout_ms per §3.1.5; mandatory MFA-confirmation thresholds; and the §6.1 / §6.4 / §6.8 Strict signature-algorithm, key-rotation, and replay-skew overrides.
- CCPE-F Behörde (reserved) — calibrated to the EU AI Act high-risk-system supervisory framework and the German BSI Online-Banking-Grundschutz baseline; Behörde-specific signature-algorithm overrides per §6.1; ≤ 1 s parent-

chain-state staleness with audit-bound-time-source attestation per §3.1.4; ≤ 500 ms phase2_timeout_ms per §3.1.5.

9.1 Reservations Catalogue

Identifier Kind Reservation

com.gimel.gauth.commerce_mandate UCP capability name Reserved by Foundation; Must Not be repurposed

commerce.* Audit event-type prefix Reserved for CCPE-F audit events

ccpe-f-* Audit-tag prefix Reserved for CCPE-F variant disambiguation per §4.6

hmac-dual-auth auth_scheme enum value Reserved per §4.2

mandate / cart / payment mandate_class enum (renamed from intent/cart/payment at v0.9.1) Reserved per §3.1

cart_propose / cart_modify / payment_propose / payment_confirm action_class enum Reserved per §3.2 / §4.4

commerce-default / commerce-strict / commerce-behoerde conformance-profile enum Reserved per §9

permit / deny / constrain verdict enum (unified at v0.9) Reserved per §2.5, §3.3, §4.4

phase2_unreachable / sca_required / mfa_confirmation_above_threshold / audit_persistence_required / parent_chain_invalid / mandate_already_consumedobligations array enum Reserved per §3.3

O / S / M / L tariff_tier enum (semantics defined in the Gimel Technologies open-core commercial schedule) Reserved per §3.5.1

gimel_managed / user_self_hosted operator_mode enum Reserved per §3.5.1

phase1 / phase2 metering phase enum Reserved per §3.5.1

ccpe_g_inbound_variant audit annotation field name Reserved per §5.1

| ccpe_f_scenario | audit annotation field name; values S1 / S2 / S3 | Reserved per §2.6 / §4.5a |

10. Acknowledgments

The Architecture Working Group acknowledges the architectural-pattern lineage shared across the CCPE family — three-service Console / Authority / Commerce-Runtime pattern; bipolar credential-bound + platform-bound enforcement; mandate-envelope shape; non-conformant-variant taxonomy convention. CCPE-F is architecturally self-contained at the commerce-domain layer; the lineage is acknowledged here without creating a normative dependency on any sibling profile.

The descriptive citation of UCP (UCP Foundation) is performed under nominative fair use and Apache License 2.0 attribution conventions and is governed by the §1.5 No-Waiver Disclaimer.

11. How to Suggest a Correction

Channels:

- Issue tracker: https://github.com/Gimel-Foundation/GiFo-RFCs/issues
- Email: info@gimelid.com
- Maintainer fast-path: include the specification or vendor name in the subject line.

Submission is governed by GiFo-RFC 0080, 0090, 0100 and is subject to the §1.5 No-Waiver Disclaimer.

12. Open Issues

a. Per-Vendor Cookbook expansion — candidates include Mastercard, Visa, PayPal, Apple Pay, Google Pay (standard payment-method-selection surface only), and at least one marketplace-tier overlay.

b. CCPE-F Strict and CCPE-F Behörde Conformance Profiles — full normative bodies.

c. GAuth Mandate Cookbook integration cross-pointer.

e. PQC algorithm migration (gated on credential layer, DNA-based ID / PQC being an Exclusion).

f. Aggregated audit-trail export format for regulator-bound submission (BaFin, EU AI Act supervisory authorities, PSD2 supervisory authorities).

g. Substrate-portable Commerce-PoA-export representation for principal-portability across deployments.

h. Alternative-substrate normative scenario — second normative scenario admissible per §4.1. i. Conformance test suite and machine-readable test vectors. j. Operator dashboard reference design for the §3.5 metering stream.

Appendix A — Vendor Cookbook: Stripe (Informative, Preliminary)

Cookbook scope-limiter. This appendix is informative. Where the appendix appears to constrain Stripe-side behaviour, the constraint is on the CCPE-F deployment's binding to Stripe, not on Stripe itself.

Vendor scope. Stripe Payments (PaymentIntents, SetupIntents, Customers), Stripe Checkout, and Stripe Connect (standard / express accounts). Stripe Issuing, Stripe Treasury, and Stripe Tax are out of scope of this cookbook.

Mandate substrate placement. The Commerce-PDP is hosted by the deployment (not by Stripe). The deployment receives Stripe webhook events at Console and reconciles them against the §3.4 audit stream.

A.1 Account-Side Setup

The deployment registers its vendor_id = "stripe" Commerce-PDP instance with Authority. The deployment configures a Stripe webhook endpoint at Console for payment_intent.*, setup_intent.*, charge.*, and payment_method.* events. Webhook signature verification per Stripe Stripe-Signature header is mandatory; verification failure Must produce commerce.platform_bound.failure with obligation webhook_signature_invalid.

A.2 Mandate-to-Stripe Object Mapping

```
CCPE-F mandate field     Stripe object field

mandate_id (payment-class)
     PaymentIntent.metadata.gimel_ccpe_f_mandate_id

parent_mandate_id (payment → cart)
     PaymentIntent.metadata.gimel_ccpe_f_parent_mandate_id

commerce_constraints.amount_cap    PaymentIntent.amount (Must
be ≤ amount_cap)

commerce_constraints.currency PaymentIntent.currency (Must
equal)

payment_constraints.payment_method_allowlist
     PaymentIntent.payment_method_types (Must be subset)

payment_constraints.payment_account_scope
     PaymentIntent.customer + PaymentIntent.payment_method
(Must be in scope)
```

```
audit_correlation.trace_id
     PaymentIntent.metadata.gimel_trace_id
```

A.3 Phase-2 Invocation

For payment_confirm actions, the Commerce-PEP invokes the Stripe API POST /v1/payment_intents (or POST /v1/payment_intents/{id}/confirm for two-step flows). The Stripe API response status field is mapped to the §4.4 verdict envelope: succeeded / requires_capture → permit; requires_action → constrain with obligation sca_required (Stripe's 3DS challenge); requires_payment_method / canceled → deny. Stripe API errors map to commerce.platform_bound.failure.

A.4 Cascade Revocation

On Authority-side revocation of a payment-class mandate, the Commerce-Runtime Must call POST /v1/payment_intents/{id}/cancel (or POST /v1/setup_intents/{id}/cancel) for the bound PaymentIntent / SetupIntent. Successful cancel emits commerce.cascade.revoked; a non-cancellable status (succeeded, canceled) is treated as terminal and emits commerce.cascade.revoked with obligation terminal_state_reached.

A.5 Audit-Trail Reconciliation

Console reconciles incoming Stripe webhook events against the persisted §3.4 audit stream by metadata.gimel_trace_id. A webhook event without a matching trace-id is the CCPE-F-NCI detection signal per §A.5a.

Stripe webhook events (payment_intent.succeeded, payment_intent.payment_failed, charge.refunded, charge.dispute.*) are consumed at the deployment's Console-side webhook handler and reconciled to the Commerce-Runtime audit events by metadata.gimel_ccpe_f_mandate_id. The reconciled record carries both the CCPE-F-side verdict envelope and the Stripe-side outcome; mismatches (e.g., a payment_intent.succeeded for a mandate that the Commerce-Runtime had reconciled deny) emit a commerce.platform_bound.failure event for operator investigation.

A.5a Variant Detection

CCPE-F-NCI detection. Stripe webhook events arriving without a matching Commerce-Runtime commerce.action_proposed audit record indicate the deployment is bypassing Phase 1 — flag as ccpe-f-nci.

CCPE-F-NCP detection. Authority-side revocation events without a matching payment_intent.cancel (or payment_method.detach where elected) within the §7.2 cascade window — flag as ccpe-f-ncp.

CCPE-F-NCO detection. PaymentIntent creation events whose metadata.gimel_ccpe_f_mandate_id references a mandate_class ≠ "payment" or whose parent chain does not resolve to a cart-class then mandate-class predecessor — flag as ccpe-f-nco.

A.6 Stripe-Specific Caveats

Stripe Connect's application_fee_amount is not represented in the v0.9 Commerce-Mandate envelope; deployments using Connect Should record the fee-allocation policy out-of-band and re-validate on reconciliation.

Stripe's idempotency-key behaviour is independent of CCPE-F's single_use invariant on payment-class mandates; deployments Must not reuse the same Stripe idempotency key across distinct Commerce-Mandate mandate_ids.

Appendix B — Vendor Cookbook: Shopify (Informative, Preliminary)

Cookbook scope-limiter. Informative. Shopify-side behaviour is not constrained by this appendix.

Vendor scope. Shopify Storefront API + Shopify Checkout + Shopify Payments. Shopify Functions and Shopify Flow are out of scope.

Mandate substrate placement. The Commerce-PDP is hosted by the deployment; Shopify is the storefront-side party to the cart and checkout.

B.1 Storefront-Side Setup

The deployment registers vendor_id = "shopify-<shop>" per Shopify shop with Authority. The deployment subscribes via Shopify webhook to carts/create, carts/update, checkouts/create, checkouts/update, orders/create, orders/paid, and orders/cancelled topics. Webhook HMAC verification per X-Shopify-Hmac-Sha256 header is mandatory.

B.2 Mandate-to-Shopify Object Mapping

```
CCPE-F mandate field     Shopify object field

mandate_id (cart-class)
     Cart.attributes.gimel_ccpe_f_mandate_id

mandate_id (payment-class)
     Order.note_attributes.gimel_ccpe_f_payment_mandate_id

parent_mandate_id
     Cart.attributes.gimel_ccpe_f_parent_mandate_id

commerce_constraints.amount_cap    Cart.cost.totalAmount (Must
be ≤ amount_cap)

vendor_scope.allowed_vendors  Must contain the shop ID

audit_correlation.trace_id    Cart.attributes.gimel_trace_id
```

B.3 Phase-2 Invocation

For cart_propose / cart_modify, the Commerce-PEP invokes Shopify Storefront GraphQL cartCreate / cartLinesAdd / cartLinesUpdate. The Storefront response cart.cost.totalAmount is checked against commerce_constraints.amount_cap. For payment_confirm, the Commerce-PEP invokes the Shopify Checkout completion mutation; success → permit; rejection due to inventory, address, or payment failure → deny.

B.4 Cascade Revocation

On Authority-side revocation of a cart-class or payment-class mandate, the Commerce-Runtime Must call the Storefront GraphQL cartAttributesUpdate setting gimel_ccpe_f_revoked = true on the bound cart, and Must reject any subsequent checkout-completion webhook for that cart with commerce.platform_bound.failure.

B.5 Audit-Trail Reconciliation

Shopify webhook events are reconciled by attributes.gimel_trace_id. A checkouts/update event setting completed_at without a corresponding payment-class mandate audit record is the CCPE-F-NCO signal per §B.5a.

B.5a Variant Detection

CCPE-F-NCI detection. Shopify webhook events (orders/create, orders/paid) without a matching Commerce-Runtime commerce.action_proposed audit record — flag as ccpe-f-nci.

CCPE-F-NCP detection. Authority-side revocations without a matching cart.attributesUpdate setting gimel_ccpe_f_revoked = true within the §7.2 cascade window — flag as ccpe-f-ncp.

CCPE-F-NCO detection. Checkout completion to payment without a corresponding cart-class to payment-class mandate transition recorded in the §3.4 audit stream — flag as ccpe-f-nco.

B.6 Shopify-Specific Caveats

Shopify discount codes and gift cards are applied at checkout and may reduce Cart.cost.totalAmount below the value initially seen at cart-class issuance; the constraint check Must be re-evaluated at payment_confirm.

Multi-currency presentment (Shopify Markets) requires the deployment to evaluate commerce_constraints.currency against presentmentCurrency, not shopCurrency.

Appendix C — Vendor Cookbook: Amazon Pay (Informative, Preliminary)

Cookbook scope-limiter. Informative. Amazon Pay-side behaviour is not constrained by this appendix.

Vendor scope. Amazon Pay Checkout v2 (CheckoutSession, ChargePermission, Charge). Amazon Pay v1 (legacy) is out of scope.

Mandate substrate placement. Commerce-PDP is hosted by the deployment; Amazon Pay is the payment-method side.

C.1 Account-Side Setup

The deployment registers vendor_id = "amazon-pay-<region>" per Amazon Pay region with Authority. The deployment configures Amazon Pay IPN (Instant Payment Notification) endpoints at Console for CHARGE_PERMISSION, CHARGE, and REFUND notification types. IPN signature verification per Amazon Pay's documented signature scheme is mandatory.

C.2 Mandate-to-Amazon-Pay Object Mapping

CCPE-F mandate field Amazon Pay object field

mandate_id (cart-class) CheckoutSession.merchantMetadata.merchantReferenceId

mandate_id (payment-class)
ChargePermission.merchantMetadata.merchantReferenceId

parent_mandate_id ChargePermission.merchantMetadata.customInformation (parent reference)

commerce_constraints.amount_cap
ChargePermission.recurringMetadata.amount.amount (Must be ≤)

commerce_constraints.currency
ChargePermission.recurringMetadata.amount.currencyCode

audit_correlation.trace_id CheckoutSession.merchantMetadata.merchantReferenceId (composite with mandate_id)

C.3 Phase-2 Invocation

For cart_propose, the Commerce-PEP invokes Amazon Pay POST /v2/checkoutSessions. For payment_confirm, the Commerce-PEP invokes POST /v2/charges against an active ChargePermission. Amazon Pay's statusDetails.state is mapped: Captured → permit;

AuthorizationInitiated → constrain with obligation awaiting_capture; Declined / Canceled → deny.

C.4 Cascade Revocation

On Authority-side revocation, the Commerce-Runtime Must call DELETE /v2/chargePermissions/{id}/close (with closureReason = "GimelMandateRevoked"). A ChargePermission already in Closed or Chargeable state with terminal Charge bound to it is treated as terminal and emits commerce.cascade.revoked with obligation terminal_state_reached.

C.5 Audit-Trail Reconciliation

Amazon Pay IPN events are reconciled by merchantReferenceId. A CHARGE_COMPLETED IPN without a matching payment-class mandate audit record is the CCPE-F-NCI signal per §C.5a.

C.5a Variant Detection

CCPE-F-NCI detection. Amazon Pay CHARGE_COMPLETED events without a matching Commerce-Runtime commerce.action_proposed audit record — flag as ccpe-f-nci.

CCPE-F-NCP detection. Authority-side revocations without a corresponding ChargePermission close action within the §7.2 cascade window — flag as ccpe-f-ncp.

CCPE-F-NCO detection. ChargePermission anchors that bind directly to a payment-class mandate without a cart-class predecessor in the parent chain — flag as ccpe-f-nco.

C.6 Amazon Pay-Specific Caveats

Amazon Pay's recurring-payment model may issue multiple Charges against a single ChargePermission; CCPE-F's single_use invariant on payment-class mandates means each recurring Charge requires a distinct payment-class mandate, even where the underlying ChargePermission is reused.

Amazon Pay's regional segmentation (US, EU, JP, UK) requires distinct vendor_id registrations and may differ in PSD2 / SCA applicability per Appendix D.

Appendix D — Vendor Cookbook: Open Banking / PSD2 (Informative, Preliminary)

Cookbook scope-limiter. Informative. PSD2-regulated ASPSP-side behaviour is not constrained by this appendix.

Vendor scope. PSD2 Payment Initiation Service (PIS) and Account Information Service (AIS) per the Berlin Group NextGenPSD2 framework or equivalent national TPP framework. Open Banking UK (OBIE) is in scope as a regional variant.

Mandate substrate placement. Commerce-PDP is hosted by the deployment, which acts as the PIS provider (TPP). The ASPSP (the PSU's bank) is the platform-side party.

D.1 PSU Authentication and Strong Customer Authentication

The PSD2 Strong Customer Authentication (SCA) requirement applies to every payment initiated through the PIS subject to the SCA exemption framework. The CCPE-F payment-class mandate Must declare mfa_confirmation_required_above at a value consistent with the SCA exemption thresholds applicable in the payment service user (PSU)'s jurisdiction at the time of payment, as published by the relevant National Competent Authority (e.g., the European Banking Authority for EU member states under the EBA Regulatory Technical Standards, the UK Financial Conduct Authority for the United Kingdom). Specific monetary thresholds vary by jurisdiction and over time and are not fixed by this RFC.

Where the proposed payment is within the SCA-required window, the Commerce-PEP at Phase 1 Must require the SCA confirmation receipt as an obligation in the obligations field per §3.3.

D.2 Mandate-to-PSD2-PIS Object Mapping

CCPE-F mandate field PSD2 PIS payment-initiation field

mandate_id (payment-class) PaymentInitiation.endToEndIdentification

parent_mandate_id PaymentInitiation.remittanceInformationStructured.reference (composite encoding)

commerce_constraints.amount_cap PaymentInitiation.instructedAmount.amount (Must be ≤)

commerce_constraints.currency PaymentInitiation.instructedAmount.currency

payment_constraints.payment_account_scope PaymentInitiation.debtorAccount.iban (tokenised reference resolved at Authority)

payment_constraints.rail_allowlist PaymentInitiation.paymentService (payments / bulk-payments / periodic-payments) + paymentProduct (sepa-credit-transfers / instant-sepa-credit-transfers / etc.)

D.3 Phase-2 Invocation

The Commerce-PEP issues a Berlin Group POST /v1/{payment-service}/{payment-product} against the ASPSP's PIS endpoint. The ASPSP's transactionStatus field is mapped: ACSC (AcceptedSettlementCompleted) → permit; ACTC (AcceptedTechnicalValidation) / PDNG (Pending) → constrain with obligation awaiting_settlement; RJCT (Rejected) / CANC (Canceled) → deny. The psuMessage and tppMessages fields are surfaced as obligation diagnostics.

D.4 Cascade Revocation

On Authority-side revocation, the Commerce-Runtime Must call the ASPSP's DELETE /v1/{payment-service}/{payment-product}/{payment-id} endpoint where revocation is supported by the ASPSP. For periodic-payment mandates, the Commerce-Runtime Must additionally revoke the AIS consent backing the standing-order arrangement. ASPSPs that do not expose a payment-cancellation endpoint Must be flagged at registration with cascade_capability = "limited"; deployments with such ASPSPs Should not declare CCPE-F Strict conformance.

D.5 Audit-Trail Reconciliation

ASPSP-side payment_initiation.status_change notifications (where the ASPSP supports webhooks; otherwise polling) are reconciled by endToEndIdentification. The composite parent-chain encoding in remittanceInformationStructured.reference is decoded at Console for parent-chain validation.

ASPSP-side payment-status notifications (payment_initiation.status_change polling responses or Push-Notification Service callbacks where the ASPSP supports them) are consumed at the deployment's Console-side handler and reconciled to the Commerce-Runtime audit events by mandate_id. The reconciled record carries both the CCPE-F-side verdict envelope and the ASPSP-side outcome; mismatches emit a commerce.platform_bound.failure event for operator investigation.

D.5a Variant Detection

CCPE-F-NCI detection. ASPSP-side payment_initiation.status_change notifications without a matching Commerce-Runtime commerce.action_proposed audit record — flag as ccpe-f-nci.

CCPE-F-NCP detection. Authority-side revocations without a corresponding ASPSP consent-withdrawal call within the §7.2 cascade window — flag as ccpe-f-ncp.

CCPE-F-NCO detection. Payment initiation requests whose Risk.PaymentContextCode references a mandate not derivable from a documented cart-class then mandate-class chain — flag as ccpe-f-nco.

D.6 PSD2-Specific Caveats

TPP licensing is a regulatory pre-condition external to this RFC; CCPE-F does not validate TPP licensing.

ASPSPs vary in API maturity, consent-model, SCA exemption claim semantics (scaExemption field), and webhook availability; deployments Should maintain a per-ASPSP capability matrix at Console.

Instant-SEPA (SCT Inst) settlement timelines (≤ 10 s end-to-end target) interact with §3.1.6 cascade-revocation latency budgets; deployments using SCT Inst Should not rely on cascade revocation as a settlement-side rollback mechanism.

Appendix E — Vendor Cookbook: W3C Payment Request API (Informative, Preliminary)

Cookbook scope-limiter. Informative. Browser-side and PaymentHandler-side behaviour is not constrained by this appendix.

Vendor scope. W3C Payment Request API as implemented by current desktop and mobile browsers, with the PaymentHandler API and Payment Method Manifest mechanism.

Mandate substrate placement. The Commerce-PDP is hosted by the merchant back-end (the deployment). The browser is the user-agent intermediary. The PaymentHandler / payment-method side is the platform-side party at Phase 2.

E.1 Merchant-Side Setup

The deployment registers vendor_id = "w3c-pr-api-<merchant-origin>" with Authority. The deployment publishes a Payment Method Manifest at the merchant origin declaring the supported payment methods and the default_applications PaymentHandler. The deployment's back-end Must verify the PaymentResponse.details cryptographic envelope (where the chosen payment method provides one, e.g. SecurePaymentConfirmation assertion) before mapping to permit.

E.2 Mandate-to-PaymentRequest Object Mapping

CCPE-F mandate field PaymentRequest / PaymentResponse field

mandate_id (payment-class) PaymentDetailsInit.id (merchant-defined; bind to mandate_id)

commerce_constraints.amount_cap PaymentDetailsInit.total.amount.value (Must be ≤ amount_cap)

commerce_constraints.currency PaymentDetailsInit.total.amount.currency

payment_constraints.payment_method_allowlist
PaymentMethodData[].supportedMethods (Must be subset)

audit_correlation.trace_id PaymentRequest.id composite encoding

E.3 Phase-2 Invocation

The browser-mediated Phase 2 is the PaymentRequest.show() flow. The PaymentResponse returned is mapped to the §4.4 verdict envelope: a successful PaymentResponse.complete("success") → permit; user cancellation → deny;

PaymentResponse.complete("fail") → deny; SecurePaymentConfirmation challenge in flight → constrain with obligation spc_assertion_pending.

E.4 Cascade Revocation

The W3C Payment Request API does not expose a post-completion revocation primitive; cascade revocation Must be effected at the merchant back-end by refusing to settle any subsequent submission referencing the revoked mandate, and by emitting commerce.cascade.revoked with obligation revocation_post_browser_handoff to flag the architectural limitation.

E.5 Audit-Trail Reconciliation

The merchant back-end reconciles each PaymentResponse to the §3.4 audit stream by PaymentRequest.id. PaymentResponses without a matching commerce.action_proposed audit record indicate browser-side replay or session-fixation and Must emit commerce.platform_bound.failure with obligation pr_response_unbound.

E.5a Variant Detection

CCPE-F-NCI detection. PaymentResponse events without a matching Commerce-Runtime commerce.action_proposed audit record — flag as ccpe-f-nci.

CCPE-F-NCP detection. Authority-side revocations followed by a successful PaymentResponse.complete("success") for the bound mandate — flag as ccpe-f-ncp (architectural limitation per §E.4).

CCPE-F-NCO detection. PaymentRequest.show() invocations whose PaymentRequest.id does not encode a cart-class predecessor reference — flag as ccpe-f-nco.

E.6 W3C-Specific Caveats

The W3C Payment Request API is implemented inconsistently across browsers; deployments Should maintain a per-browser capability matrix and Should treat absent SecurePaymentConfirmation support as a contraindication for CCPE-F Strict conformance.

The browser intermediary is outside the deployment's trust boundary; the §6.3 mutual-TLS posture does not extend across the user-agent layer. This is an inherent architectural limitation of the W3C Payment Request API, not a CCPE-F-NCO violation.

* * *

Disclaimer: ALL DOCUMENTS AND THE INFORMATION CONTAINED THEREIN ARE PROVIDED ON AN “AS IS” BASIS AND THE CONTRIBUTOR, THE ORGANIZATION THEY REPRESENT OR ARE SPONSORED BY (IF ANY), THE GIMEL FOUNDATION, AND ANY APPLICABLE MANAGERS OF ALTERNATE DOCUMENT STREAMS, DISCLAIM ALL WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO ANY WARRANTY THAT THE USE OF THE INFORMATION THEREIN WILL NOT INFRINGE ANY RIGHTS OR ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE.

PRODUCT NAMES, TRADEMARKS, AND REGISTERED TRADEMARKS REFERENCED IN THIS DOCUMENT ARE THE PROPERTY OF THEIR RESPECTIVE OWNERS AND ARE USED FOR IDENTIFICATION PURPOSES ONLY. NO ENDORSEMENT IS IMPLIED.

* * *